

資安科技與管理

Module2.從資安法到資訊安全管理制度



大綱

- 由資安法看資訊安全管理制度
 - 可信任 AI 與我國規劃
 - ISO27000系列認證
 - PDCA 與 ISMS
 - ISO27001的主要元素
 - ISO27001 的建議控制措施
-
- 參考文獻：
 - ISO/IEC27001:2022;ISO/IEC27002:2022;
 - CNS27001;CNS27002

請先思考以下的問題

- 從國家的角度，該做什麼樣子的資安政策？
- 對於不同種類的企業，是否該有不同的方式要求？

我國資安推動歷程

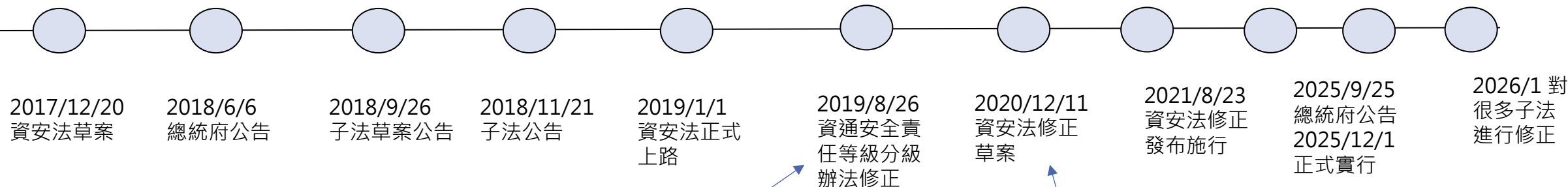


目的：

資通安全管理法第一條：為積極推動國家資通安全政策，加速建構國家資通安全環境，以保證國家安全，維護社會公共利益

- 針對數發部與資安署的成立作調整。明確主管機關權責、擴大稽核、強化關鍵基礎設施與特定非公務機關管理、資安專職人員要求，以及危害國家資通安全產品管理等。

2024/7/4
提出修正版



- 進一步細化了責任等級的標準，特別是對高風險行業的要求更加明確，並加強了對不同責任等級的具體防護要求。
- 更多的監督、稽核和通報規範，確保各機構能夠按其責任等級採取適當的資安措施，並且在發生資安事件時，能夠迅速應對並進行通報。

- 針對「資通安全管理法施行細則」進行了具體調整，涉及到擴大適用範圍、強化資安事件通報機制、加強罰則執行以及重要基礎設施的資安要求等。

資安法修法主軸

修法主軸	舊法	新法	主要條文
主管機關重整	主管機關為行政院	明定主管機關為數位發展部，國家資安業務由資安署辦理	新 §2
國家資安治理法制化	沒有把國家資通安全會報完整寫入法律	明定行政院召開國家資通安全會報，跨中央、地方協調並追蹤管考	新增 §5
中央直接稽核權強化	稽核主要由上級機關、中央目的事業主管機關進行	數位部可直接定期或不定期稽核公務機關及特定非公務機關	新增 §8
委外/ 供應鏈管理強化	有委外監督概念，但規範較簡略	要求適當受託者、有效資安機制、第三方驗證或完善措施，以及書面契約明訂責任	新 §10
危害國家資安產品管制	無完整法源	定義「危害國家資通安全產品」，公務機關原則禁止使用，特定非公務機關亦可被限制 / 禁止	新增 §3(11)、§11、§27

資安法修法主軸 (續)

修法主軸	舊法	新法	主要條文
資安專職人力制度化	有資安人力要求，但較偏責任等級配套	明文要求依責任等級配置資安專職人員，並建立訓練、績效與重大事件調度機制	新 §7、§18、§20、§21
資安人員適任性查核	無此完整制度	得對資安專職人員及資安考試錄取者進行適任性查核	新增 §19
特定非公務機關也要有 CISO	資安長主要針對公務機關	特定非公務機關亦明文要求設置資通安全長	新增 §23
重大事件行政調查權	重點是通報、應變、改善	重大事件可要求陳述、第三方鑑識報告，甚至進入場所實施必要檢查	新增 §25、§31
個資外洩與資安事件銜接	資安法、個資法關係較不明確	明定資安事件涉及個資外洩時，仍應另依《個資法》處理	新增 §33

新版資安法五大重點

- 國家資安會報入法。新版第 5 條要求行政院定期召開國家資通安全會報，由院長或副院長擔任召集人，且決議事項要追蹤管考。這代表資安治理不再只是個別機關自行負責，而更明確變成中央—地方跨機關治理。
- 資安署直接稽核權。新版第 8 條讓主管機關可直接稽核公務機關和特定非公務機關，而且稽核缺失後要提出改善報告，年度稽核計畫與成果還要送國家資安會報備查。
- 供應鏈/ 委外管理具體化。新版第 10 條不只要求選任適當廠商，而是要求受託者建立有效資安管理机制，相關程序與環境要有適當資安措施或第三方驗證，且雙方權利義務與違約責任要寫進契約。
- 人員治理。新版除了要求配置資安專職人員，也加入職能訓練、重大事件時跨機關調度支援，以及資安專職人員的適任性查核。這已經從「有沒有資安人員」往「人員是否適任、能否調度」前進。
- 重大資安事件從通報走向調查。新版第 25 條讓中央目的事業主管機關可要求當事人或關係人到場說明、要求獨立第三方鑑識或調查報告，也可派員到相關場所實施必要檢查；受調查者不得規避、妨礙或拒絕。

資通安全管理法子法

資通安全管理法施行細則

特定非公務機關資通安全維護計畫
實施情形稽核辦法

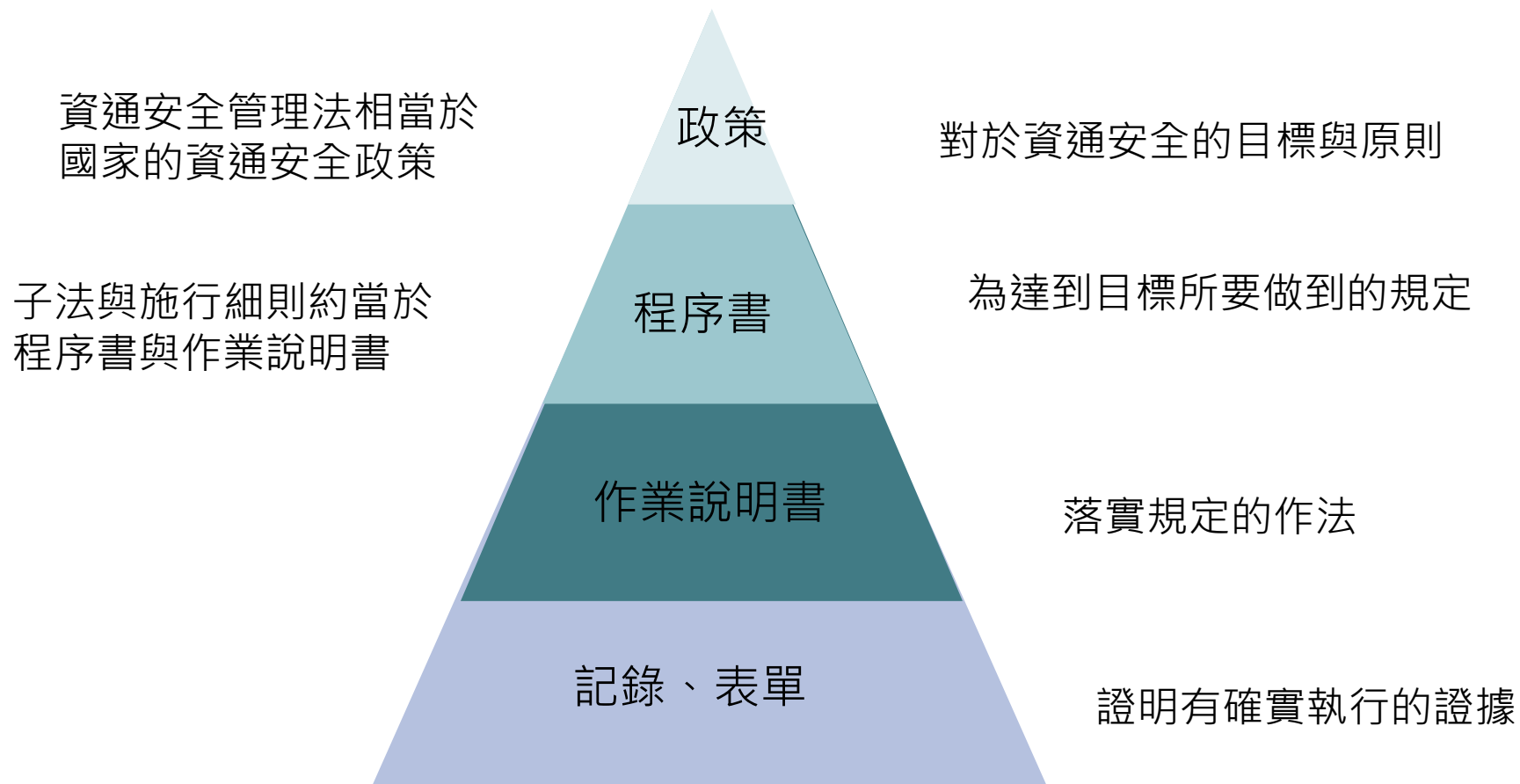
資通安全責任等級分級辦法

資通安全情資分享辦法

資通安全事件通報應變及演練辦法

公務機關所屬人員資通安全事項獎
懲辦法

由四階文件架構來看資通安全管理法



原本資通安全管理法之大綱

第一章總則

- 第1條目的
- 第2條主管機關
- 第3條定義
- 第4條政府對於資通安全之責任
- 第5條主管機關之責任
- 第6條主管機關資安委外之要求
- 第7條主管機關分類分級之責任
- 第8條主管機關對建立資通安全
情報分享機制之要求
- 第9條對公務機關與非公務機關
之要求

第四章罰則(第19至第21條)

第五章附則(第22、23條)

第二章公務機關資通安全管理

- 第10條建立資通安全維護計畫
- 第11條資通安全長
- 第12條報告執行狀況的責任
- 第13條對所屬機關之稽核責任
- 第14條資安事件之應變
- 第15條獎勵辦法

第三章特定非公務機關資通 安全管理

- 第16條關鍵基礎設施核定辦法與
提供者之責任
- 第17條其他非特定公務機關之核
定與責任
- 第18條資安事件之應變與通報

第一章 總則	
第1條	立法目的
第2條	主管機關及資安專責機關
第3條	用詞定義
第4條	政府推動資通安全之責任
第5條	國家資通安全會報與跨機關協調
第6條	主管機關之國家資安治理責任
第7條	資通安全責任等級及防護要求
第8條	資安維護計畫之中央稽核
第9條	資通安全情資分享機制
第10條	委外資安管理及資安演練

第四章 罰則	
第28條	違反資安義務之人員懲處
第29條	未通報資安事件之罰則
第30條	違反資安管理義務之罰則
第31條	規避、妨礙或拒絕調查之罰則

第五章 附則	
第32條	資安事務委託及主管機關協調
第33條	資安事件涉及個資外洩之處理
第34條	施行細則
第35條	施行日期

第二章 公務機關資通安全管理	
第11條	危害國家資通安全產品之限制
第12條	資通安全長
第13條	資通安全維護計畫
第14條	資安維護計畫實施情形之提出
第15條	所屬及所監督機關之稽核責任
第16條	稽核缺失改善與追蹤
第17條	資通安全事件通報、應變與改善
第18條	資安專職人員、訓練及調度
第19條	資安專職人員適任性查核

第三章 特定非公務機關資通安全管理	
第20條	關鍵基礎設施提供者之資安管理
第21條	其他特定非公務機關之資安管理
第22條	資安維護計畫、稽核及改善辦法
第23條	資通安全長
第24條	資安事件通報、應變與改善
第25條	重大資安事件之行政調查
第26條	資安人員獎勵
第27條	危害國家資通安全產品之管制

想一想

- 新舊條文有哪些差異？為何要加入這些？有哪些背後的原因？
- 你在看法規的時候，有哪些觀察重點？

適用範圍

罰則

法遵有沒有商機 (誤)

最近似乎罰則很多人討論

- 第 28 條 公務機關所屬人員未依本法規定辦理者，應按其情節輕重，依相關規定予以懲戒或懲處。前項懲處事項之辦法，由主管機關定之。特定非公務機關所屬人員未依本法規定辦理，情節重大者，由特定非公務機關依規定予以懲處。
原本 500 萬
- 第 29 條 特定非公務機關未依第二十四條第二項規定，通報資通安全事件，由中央目的事業主管機關處新臺幣三十萬元以上一千萬元以下罰鍰，並令限期改正；屆期未改正者，按次處罰之。
- 第 30 條 特定非公務機關有下列情形之一者，由中央目的事業主管機關令限期改正；屆期未改正者，按次處新臺幣十萬元以上五百萬元以下罰鍰 ← 原本 100 萬
 - 一、未依第二十條第二項或第二十一條第一項規定，訂定、修正或實施資通安全維護計畫，或違反第二十二條所定辦法中有關資通安全維護計畫必要事項之規定。
 - 二、未依第二十條第三項或第二十一條第二項規定，向中央目的事業主管機關提出資通安全維護計畫之實施情形，或違反第二十二條所定辦法中有關資通安全維護計畫實施情形提出之規定。
 - 三、未依第八條第二項、第二十條第五項或第二十一條第三項規定，提出改善報告送交中央目的事業主管機關，或違反第二十二條所定辦法中有關改善報告提出之規定。
 - 四、未依第二十四條第一項規定，訂定資通安全事件之通報及應變機制，或違反第二十四條第四項所定辦法中有關通報及應變機制必要事項之規定。
 - 五、未依第二十四條第三項規定，向中央目的事業主管機關提出或向主管機關送交資通安全事件之調查、處理及改善報告，或違反第二十四條第四項所定辦法中有關報告提出、送交之規定。
 - 六、違反第二十四條第四項所定辦法中有關通報內容、演練作業之規定。
- 第 31 條 違反第二十五條第三項規定，規避、妨礙或拒絕調查者，由中央目的事業主管機關處新臺幣十萬元以上一百萬元以下罰鍰。

資通安全管理法施行細則當中有些比較重要的內容

- 本法第十三條、第二十條第二項及第二十一條第一項所定資通安全維護計畫，應包括下列事項：
 - 一、核心業務及其重要性。
 - 二、資通安全政策及目標。
 - 三、資通安全推動組織。
 - 四、專職人力及經費之配置。
 - 五、資通安全長之配置。
 - 六、資通系統之盤點，並標示核心資通系統及相關資產。
 - 七、資通安全風險管理。
 - 八、資通安全防護及控制措施。
 - 九、資通安全事件通報、應變及演練相關機制。
 - 十、資通安全情資之評估及因應機制。
 - 十一、資通系統或服務委外辦理之管理措施。
 - 十二、所屬人員辦理業務涉及資通安全事項之考核機制。
 - 十三、資通安全維護計畫與實施情形之持續精進及績效管理機制。
- 各機關依本法第十四條、第二十條第三項或第二十一條第二項規定提出資通安全維護計畫實施情形，應包括前項各款之執行成果及相關說明。
- 第一項資通安全維護計畫之訂定、修正、實施及前項實施情形之提出，公務機關經本法第十四條規定收受其資通安全維護計畫實施情形之機關同意，得由收受機關或其所屬、所監督之公務機關、所轄鄉(鎮、市)公所、直轄市山地原住民區公所及鄉(鎮、市)民代表會、直轄市山地原住民區民代表會辦理；特定非公務機關經其中央目的事業主管機關同意，得由其中央目的事業主管機關、中央目的事業主管機關所屬、所監督公務機關或中央目的事業主管機關所管特定非公務機關辦理。

核心業務與核心系統的定義，以及重大資通安全事件

- 第 10 條 前條第一項第一款所定核心業務，其範圍如下：
 - 一、公務機關依其組織法規，足認該業務為機關核心權責所在。
 - 二、各機關維運、提供關鍵基礎設施所必要之業務。
 - 三、公營事業與特定財團法人及受政府控制之事業、團體或機構之主要服務或功能。
 - 四、各機關依資通安全責任等級分級辦法第四條第一款至第五款或第五條第一款至第五款涉及之業務。
- 前條第一項第六款所稱核心資通系統，指支持核心業務持續運作必要之系統，或依資通安全責任等級分級辦法附表九資通系統防護需求分級原則之規定，判定其防護需求等級為高者。
- 第 5 條 本法第四條第一項第五款所稱重大資通安全事件，指民間單位有下列情形之一者，並對社會公共利益、國民生活或經濟活動有重大影響之虞，且受社會矚目之事件：
 - 一、核心業務資訊遭嚴重洩漏。
 - 二、核心業務資訊或核心資通系統遭嚴重竄改。
 - 三、核心資通系統之運作受影響或停頓，無法於可容忍中斷時間內回復正常運作。

資通安全責任等級分級辦法

第1條本辦法依資通安全管理法(以下簡稱本法)第七條第一項規定訂定之。

第2條公務機關及特定非公務機關(以下簡稱各機關)之資通安全責任等級，由高至低，分為A級、B級、C級、D級及E級。

第3條 行政院應每三年核定自身資通安全責任等級，送主管機關備查；行政院直屬機關應每三年提交自身、所屬、所監督之公務機關及所管之特定非公務機關之資通安全責任等級，報主管機關核定。
直轄市、縣(市)政府應每三年提交自身、所屬、所監督之公務機關，與所轄鄉(鎮、市)公所、直轄市山地原住民區公所、鄉(鎮、市)民代表會及直轄市山地原住民區民代表會及其所屬或所監督之公務機關之資通安全責任等級，報主管機關核定；直轄市及縣(市)議會應每三年提交自身資通安全責任等級，報主管機關核定。
總統府、國家安全會議、立法院、司法院、考試院及監察院應每三年核定自身、所屬、所監督之公務機關及所管之特定非公務機關之資通安全責任等級，送主管機關備查。
各機關因組織或業務調整，致須變更原資通安全責任等級時，應即依前三項規定程序辦理等級變更；有新設機關時，亦同。
第一項至第三項公務機關辦理資通安全責任等級之提交或核定，就公務機關或特定非公務機關內之單位，認有另列與該機關不同等級之必要者，得考量其業務性質，依第四條至第十條規定認定之。

資通安全責任等級分級辦法(續)

第4條各機關有下列情形之一者，其資通安全責任等級為A級：

- 一、業務涉及國家機密。
- 二、業務涉及外交、國防或國土安全事項。
- 三、業務涉及全國性民眾服務或跨公務機關共用性資通系統之維運。
- 四、業務涉及全國性民眾或公務員個人資料檔案之持有。
- 五、屬公務機關，且業務涉及全國性之能源、水資源、通訊傳播、交通、銀行與金融、緊急救援事項。
- 六、屬關鍵基礎設施提供者，且業務經中央目的事業主管機關考量其提供或維運關鍵基礎設施服務之用戶數、市場占有率、區域、可替代性，認其資通系統失效或受影響，對社會公共利益、民心士氣或民眾生命、身體、財產安全將產生災難性或非常嚴重之影響。
- 七、屬公立醫學中心。

第5條各機關有下列情形之一者，其資通安全責任等級為B級：

- 一、業務涉及公務機關捐助、資助或研發之國家核心科技資訊之安全維護及管理。
- 二、業務涉及區域性、地區性民眾服務或跨公務機關共用性資通系統之維運。
- 三、業務涉及區域性或地區性民眾個人資料檔案之持有。
- 四、業務涉及中央二級機關及所屬各級機關(構)共用性資通系統之維運。
- 五、屬公務機關，且業務涉及區域性或地區性之關鍵基礎設施事項。
- 六、屬關鍵基礎設施提供者，且業務經中央目的事業主管機關考量其提供或維運關鍵基礎設施服務之用戶數、市場占有率、區域、可替代性，認其資通系統失效或受影響，對社會公共利益、民心士氣或民眾生命、身體、財產安全將產生嚴重影響。
- 七、屬公立區域醫院或地區醫院。

第6條(1)各機關維運自行或委外設置、開發之資通系統者，其資通安全責任等級為C級。

(2)前項所定自行或委外設置之資通系統，指具權限區分及管理功能之資通系統。

資通安全責任等級分級辦法(續)

第7條各機關自行辦理資通業務，未維運自行或委外設置、開發之資通系統者，其資通安全責任等級為D級。

第8條各機關有下列情形之一者，其資通安全責任等級為E級：

- 一、無資通系統且未提供資通服務。
- 二、屬公務機關，且其全部資通業務由其上級機關、監督機關或上開機關指定之公務機關兼辦或代管
- 三、屬特定非公務機關，且其全部資通業務由其中央目的事業主管機關、中央目的事業主管機關所屬公務機關、中央目的事業主管機關所管特定非公務機關或出資之公務機關兼辦或代管。

第9條各機關依第四條至前條規定，符合二個以上之資通安全責任等級者，其資通安全責任等級列為其符合之最高等級。

第10條 各機關之資通安全責任等級依前六條規定認定之。但第三條第一項至第三項之公務機關提交或核定資通安全責任等級時，得考量下列事項對國家安全、社會公共利益、人民生命、身體、財產安全或公務機關聲譽之影響程度，調整各機關之等級：

- 一、業務涉及外交、國防、國土安全或關鍵基礎設施者，其中斷或受妨礙。
- 二、業務涉及個人資料、公務機密或其他依法規或契約應秘密之資訊者，其資料、公務機密或其他資訊之數量與性質，及遭受未經授權之存取、使用、控制、洩漏、破壞、竄改、銷毀或其他侵害。
- 三、各機關依層級之不同，其功能受影響、失效或中斷。
- 四、其他與資通系統之提供、維運、規模或性質相關之具體事項。

資通安全責任等級分級辦法(續)

第11條 各機關應依其資通安全責任等級，辦理附表一至附表八之事項。

- 各機關自行或委外開發之資通系統應依附表九所定資通系統防護需求分級原則完成資通系統分級，並依附表十所定資通系統防護基準執行控制措施。特定非公務機關之中央目的事業主管機關就特定類型資通系統之防護基準認有另為規定之必要者，得自行擬訂防護基準，報請主管機關核定後，依其規定辦理。
- 公務機關經其上級機關或監督機關同意者，準用中央目的事業主管機關依前項所定防護基準相關規定辦理；其他特定非公務機關經其中央目的事業主管機關同意者，亦同。
- 各機關辦理附表一至附表八所定事項或執行附表十所定控制措施，因技術限制、個別資通系統之設計、結構或性質等因素，就特定事項或控制措施之辦理或執行顯有困難者，得經第三條第一項後段及第二項所定其等級提交機關或同條第一項前段及第三項所定其等級核定機關同意，並報請主管機關備查後，免執行該事項或控制措施。等級提交機關有前段情形者，經主管機關同意後，免予執行；其為等級核定機關者，經報請主管機關備查後，免予執行。
- 公務機關應依主管機關指定之方式，提報第一項及第二項事項之辦理情形。
- 中央目的事業主管機關得要求其所管特定非公務機關，依其指定之方式提報第一項及第二項事項之辦理情形。
- 附表一至附表十之規定，各機關因修正而須於所定期限內辦理新增或異動項目，辦理期限自修正施行之日起算。

第12條(1)本辦法之施行日期，由主管機關定之。

(2)本辦法修正條文自發布日施行。

資通安全責任等級分級辦法附表一資通安全責任等級A級之公務機關應辦事項

制度面向	辦理項目	辦理項目細項	辦理內容
管理面	資通系統分級及防護基準		針對自行或委外開發之資通系統，依附表九完成資通系統分級，並完成附表十之控制措施；其後應每年至少檢視一次資通系統分級及其防護基準之妥適性。
	資訊安全管理系統之導入及通過公正第三方之驗證		全部核心資通系統導入CNS 27001或ISO 27001等資訊安全管理系統標準、其他具有同等或以上效果之系統或標準或其他公務機關自行發展並經主管機關認可之標準，完成公正第三方驗證，並持續維持其驗證有效性。
	資通安全專職人員		配置四人以上。
	內部資通安全稽核		每年辦理二次。
	業務持續運作演練		全部核心資通系統每年辦理一次。
	資安治理成熟度評估		每年辦理一次。

資通安全責任等級分級辦法附表一資通安全責任等級A級之公務機關應辦事項

制度面向	辦理項目	辦理項目細項	辦理內容
技術面	安全性檢測	弱點掃描	全部核心資通系統每年辦理二次。
		系統滲透測試	全部核心資通系統每年辦理一次。
	資通安全健診	網路架構檢視	每年辦理一次。
		網路惡意活動檢視	
		使用者端電腦惡意活動檢視	
		伺服器主機惡意活動檢視	
		目錄伺服器設定及防火牆連線設定檢視	
		核心資通系統資料庫安全檢視	

資通安全責任等級分級辦法附表一資通安全責任等級A級之公務機關應辦事項

制度面向	辦理項目	辦理項目細項	辦理內容
技術面	資通安全威脅偵測管理機制		完成監控管理機制建置，並持續維運及依主管機關指定之方式提交監控管理資料。其監控範圍應包括本表所定「端點偵測及應變機制」與「資通安全防护」之辦理內容、目錄服務系統與核心資通系統之日誌紀錄及資通設備紀錄。
	政府組態基準		依主管機關公告之項目，完成政府組態基準導入作業，並持續維運。。
	資通安全弱點管理		一、知悉資通安全弱點時，應適時修補或採行緩解措施。 二、依主管機關指定方式導入弱點管理作業，並持續維運。
	端點偵測及應變機制		完成端點偵測及應變機制導入作業，並持續維運及依主管機關指定之方式提交偵測資料。

資通安全責任等級分級辦法附表一資通安全責任等級A級之公務機關應辦事項

制度面向	辦理項目	辦理項目細項	辦理內容
技術面	資通安全防護	防毒軟體	完成各項資通安全防護措施之啟用，並持續使用及適時進行軟、硬體之必要更新或升級。
		網路防火牆	
		具有郵件伺服器者，應備電子郵件過濾機制	
		入侵偵測及防禦機制	
		具有對外服務之核心資通系統者，應備應用程式防火牆	
		進階持續性威脅攻擊防禦措施	

資通安全責任等級分級辦法附表一資通安全責任等級A級之公務機關應辦事項

制度面向	辦理項目	辦理項目細項	辦理內容
認知與訓練	資通安全教育訓練	資通安全專職人員	每年至少接受十二小時以上之資通安全專業課程訓練或資通安全職能訓練。
		資通安全專責人員以外之資訊人員	每人每二年接受三小時以上之資通安全專業課程訓練或資通安全職能訓練，且每年接受三小時以上之資通安全通識教育訓練。
		一般使用者及主管	每人每年接受三小時以上之資通安全通識教育訓練。
	資通安全專業證照及職能訓練證書		資通安全專職人員各自持有證照及證書各一張以上，並持續維持證照及證書之有效性

資通安全責任等級分級辦法附表九資通系統防護需求分級原則

	高	中	普
機密性	發生資通安全事件致資通系統受影響時，可能造成未經授權之資訊揭露，對機關之營運、資產或信譽等方面將產生非常嚴重或災難性之影響。	嚴重之影響。	有限之影響。
完整性	發生資通安全事件致資通系統受影響時，可能造成資訊錯誤或遭竄改等情事，對機關之營運、資產或信譽等方面將產生非常嚴重或災難性之影響。	嚴重之影響。	有限之影響。
可用性	發生資通安全事件致資通系統受影響時，可能造成對資訊、資通系統之存取或使用之中斷，對機關之營運、資產或信譽等方面將產生非常嚴重或災難性之影響。	嚴重之影響。	有限之影響。
法律遵循性	如未確實遵循資通系統設置或運作涉及之資通安全相關法令，可能使資通系統受影響而導致資通安全事件，或影響他人合法權益或機關執行業務之公正性及正當性，並使機關所屬人員負刑事責任。	或其所屬人員受行政罰、懲戒或懲處。	其他資通系統設置或運作於法令有相關規範之情形。

資通安全責任等級分級辦法附表十資通系統防護基準

		高	中	普
存取控制	帳號管理	一、應依機關規定之情況及條件，使用資通系統。 二、監控資通系統帳號，如發現帳號違常使用時，回報管理者。 三、等級「中」之所有控制措施。	一、機關應定義各系統之間置時間或可使用期限與資通系統之使用情況及條件。 二、逾越機關所許可之間置時間或可使用期限時，系統應自動將使用者登出。 三、等級「普」之所有控制措施。	一、建立帳號管理機制，包含帳號之申請、建立、修改、啟用、停用及刪除之程序。 二、已逾期之臨時或緊急帳號應刪除或禁用。 三、資通系統間置帳號應禁用。 四、定期審核資通系統帳號之申請、建立、修改、啟用、停用及刪除。
	最小權限	採最小權限原則，僅允許使用者（或代表使用者行為之程序）依機關任務及業務功能，完成指派任務所需之授權存取。		
	遠端存取	一、對於每一種允許之遠端存取類型，均應先取得授權，建立使用限制、組態需求、連線需求及文件化。 二、使用者之權限檢查作業應於伺服器端完成。 三、應監控遠端存取機關內部網段或資通系統後臺之連線。 四、應採用加密機制。 五、遠端存取之來源應為機關已預先定義及管理之存取控制點。		

資通安全責任等級分級辦法附表十資通系統防護基準

		高	中	普
事件日誌與 可歸責性	紀錄事件	一、應定期審查機關所保留資通系統產生之日誌。 二、等級「普」之所有控制措施。		一、訂定日誌之記錄時間週期及留存政策，並保留日誌至少六個月。 二、確保資通系統有記錄特定事件之功能，並決定應記錄之特定資通系統事件。 三、應記錄資通系統管理者帳號所執行之各項功能。
	日誌紀錄內容	資通系統產生之日誌應包含事件類型、發生時間、發生位置及任何與事件相關之使用者身分識別等資訊，採用單一日誌機制，確保輸出格式之一致性，並應依資通安全政策及法規要求納入其他相關資訊。		
	日誌儲存容量	依據日誌儲存需求，配置所需之儲存容量。		
	日誌處理失效之回應	一、機關規定需要即時通報之日誌處理失效事件發生時，資通系統應於機關規定之時效內，對特定人員提出警告。 二、等級「中」及「普」之所有控制措施。		

資通系統於日誌處理失效時，應採取適當之行動。

資通安全責任等級分級辦法附表十資通系統防護基準

		高	中	普
事件日誌與可歸責性	時戳及校時	一、資通系統應使用系統內部時鐘產生日誌所需時戳，並可以對應到世界協調時間 (UTC) 或格林威治標準時間 (GMT) 。 二、系統內部時鐘應定期與基準時間源進行同步。		
	日誌資訊之保護	一、定期備份日誌至原系統外之其他實體系統。 二、等級「中」之所有控制措施。	一、應定期測試備份資訊，以驗證備份媒體之可靠性及資訊之完整性。 二、等級「普」之所有控制措施。	對日誌紀錄之存取管理，僅限於有權限之使用者。

資通安全責任等級分級辦法附表十資通系統防護基準

		高	中	普
營運持續計畫	系統備份	一、應將備份還原，作為營運持續計畫演練之一部分。 二、應建立資料異地備份機制。 三、等級「中」之所有控制措施。	一、應定期測試備份資料，以驗證備份媒體之可靠性及資訊之完整性。 二、等級「普」之所有控制措施。	一、訂定資料可容忍損失之時間要求。 二、執行資料備份。
	系統備援	一、應將備援啟動作為營運持續計畫演練之一部分。 二、等級「中」之所有控制措施。	一、應定期測試原服務中斷時，於最大可容忍中斷時間內，由備援設備或其他方式取代並提供服務。 二、等級「普」之所有控制措施。	訂定資通系統從中斷後至重新恢復服務之最大可容忍中斷時間要求。

資通安全責任等級分級辦法附表十資通系統防護基準

		高	中	普
識別與鑑別	內部使用者之識別與鑑別	一、對資通系統之存取採取多因子鑑別技術。 二、等級「中」及「普」之所有控制措施。 資通系統應識別及鑑別使用者，並禁止使用者使用共用帳號。		
	身分驗證管理	一、身分驗證機制應防範自動化程式之登入或密碼更換嘗試。 二、密碼重設機制對使用者重新身分確認後，發送一次性及具有時效性符記。 三、等級「普」之所有控制措施。		一、使用預設密碼登入系統時，應於登入後要求立即變更。 二、身分驗證相關資訊不以明文傳輸。 三、具備帳戶鎖定機制，帳號登入進行身分驗證失敗達五次後，至少十五分鐘內不允許該帳號繼續嘗試登入或使用機關自建之失敗驗證機制。 四、使用密碼進行驗證時，應強制最低密碼複雜度；依機關密碼效期規定變更密碼。 五、密碼變更時，至少不可以與前三次使用過之密碼相同。 六、第四點及第五點所定措施，對外部使用者，機關得自行規範辦理。

資通安全責任等級分級辦法附表十資通系統防護基準

		高	中	普
識別與鑑別	鑑別資訊 保護	一、資通系統如以密碼進行鑑別時，該密碼應經雜湊或其他適當方式處理後儲存。 二、等級「普」之所有控制措施。。		資通系統應遮蔽鑑別過程中之資訊。

資通安全責任等級分級辦法附表十資通系統防護基準

		高	中	普
系統與服務 獲得	需求階段	針對系統安全需求(含機密性、可用性、完整性)，以檢核表方式進行確認。		
	設計階段	一、根據系統功能與要求，識別可能影響系統之威脅，進行風險分析及評估。 二、將風險評估結果回饋需求階段之檢核項目，並提出安全需求修正。		無要求。
	開發階段	一、執行「源碼掃描」安全檢測。 二、具備系統嚴重錯誤之通知機制。 三、等級「中」及「普」之所有控制措施。	一、應針對安全需求實作必要控制措施。 二、應注意避免軟體常見漏洞及實作必要控制措施。 三、發生錯誤時，使用者頁面僅顯示簡短錯誤訊息及代碼，不包含詳細之錯誤訊息。	
	測試階段	一、執行「滲透測試」安全檢測。 二、等級「中」及「普」之所有控制措施。	執行「弱點掃描」安全檢測。	

資通安全責任等級分級辦法附表十資通系統防護基準

		高	中	普
系統與服務 獲得	部署與維 運階段	一、於系統發展生命週期之維運階段，須注意版本控制與變更管理。 二、等級「普」之所有控制措施。		一、於部署環境中應針對相關資通安全威脅，進行更新與修補。 二、識別並關閉不必要服務及埠口。 三、資通系統不使用預設密碼。 四、執行系統源碼備份。
	委外階段	資通系統開發如委外辦理，應將系統發展生命週期各階段依等級將安全需求(含機密性、可用性、完整性)納入委外契約。		
	獲得程序	一、開發、測試及正式作業環境應為區隔。 二、等級「普」之所有控制措施。		識別資通系統使用之第三方軟體、服務、函式庫或其他元件。
	系統文件	應儲存與管理系統發展生命週期之相關文件。		

資通安全責任等級分級辦法附表十資通系統防護基準

		高	中	普
系統與通訊 保護	傳輸之機密性與完整性	一、資通系統應採用加密機制，以防止未授權之資訊揭露或偵測資訊之變更。但傳輸過程中有替代之實體保護措施者，不在此限。 二、使用公開、國際機構驗證且未遭破解之演算法。 三、支援演算法最大長度金鑰。 四、加密金鑰或憑證週期性更換。 五、伺服器端之金鑰保管應訂定管理規範及實施應有之安全防護措施。	無要求。	無要求。
	資料儲存之安全	資通系統重要組態設定檔案及其他具保護需求之資訊應加密或以其他適當方式儲存。	無要求。	無要求。

資通安全責任等級分級辦法附表十資通系統防護基準

		高	中	普
系統與資訊 完整性	漏洞修復	一、定期確認資通系統相關漏洞修復之狀態。 二、等級「普」之所有控制措施。		系統之漏洞修復應測試有效性及潛在影響，並定期更新。
	資通系統 監控	一、資通系統應採用自動化工具監控進出之通信流量，並於發現不尋常或未授權之活動時，針對該事件進行分析。 二、等級「中」之所有控制措施。		發現資通系統有被入侵跡象時，應通報機關特定人員。
	軟體及資 訊完整性	一、應定期執行軟體與資訊完整性檢查。 二、等級「中」之所有控制措施。		無要求。

OECD 可信賴 AI 原則

OECD > Topics > AI principles

AI principles

The OECD AI Principles are the first intergovernmental standard on AI. They promote innovative, trustworthy AI that respects human rights and democratic values. Adopted in 2019 and updated in 2024, they are composed of five values-based principles and five recommendations that provide practical and flexible guidance for policymakers and AI actors.

Policy sub-issue

OECD.AI Policy Observatory

Key links

[The state of implementation of the OECD AI Principles](#) >

[The OECD AI Work Blog](#) >

Available in: **English** français

- 2019 年發布
- 2024 年更新

About the OECD AI Principles

AI offers considerable benefits in areas like healthcare, productivity and scientific research. To also harness its potential, digital information, data, innovation and

<https://www.oecd.org/en/topics/ai-principles.html>

OECD 可信賴 AI 原則 (Principles of Trustworthy AI)(2024) – 價值為基礎的原則 (Values-based Principles)

- 包容性成長、永續發展與福祉 (Inclusive growth, sustainable development and well-being)
 - AI 應促進包容的經濟成長、社會福祉與環境永續，避免排擠與不平等。
- 尊重法治、人權與民主價值，並考量公平與隱私 (Respect for the rule of law, human rights and democratic values, including fairness and privacy) ← 改的主要是這條
 - AI 必須遵守法治、人權與民主原則，保護隱私並避免不公平歧視。
- 透明與可解釋性 (Transparency and explainability)
 - AI 系統的資料來源、決策邏輯與結果應可理解與追溯，增強使用者信任。
- 穩健性、安全與人身安全 (Robustness, security and safety)
 - AI 應在生命週期內維持穩健，抵禦惡意攻擊或誤用，並提供故障防護與緊急覆寫機制。
- 問責 (Accountability)
 - AI 的開發者與部署者應對 AI 的使用及其社會影響承擔責任，並建立治理與補救機制。

OECD 可信賴 AI 原則 (Principles of Trustworthy AI)(2024) – 對政策制定者的建議 (Recommendations for Policymakers)

- 投資 AI 研究與發展 (Investing in AI research and development)
 - 支持前沿 AI 研發，以確保安全與負責任的技術創新。
- 培育包容性的 AI 生態系統 (Fostering an inclusive AI-enabling ecosystem)
 - 建立支援創業、教育與基礎設施的生態系，促進多元參與。
- 建立可互操作的治理與政策環境 (Shaping an enabling interoperable governance and policy environment for AI)
 - 制定跨部門、跨國界的標準與規範，促進互操作性與法規一致性。
- 建設人力能力並準備就業市場轉型 (Building human capacity and preparing for labour market transition)
 - 提升勞動力技能，支持因 AI 導致的工作型態變化與再培訓。
- 促進可信任 AI 的國際合作 (International co-operation for trustworthy AI)
 - 推動跨國合作，共享最佳實務與風險治理經驗，以確保全球 AI 的可信任發展。

歐盟的可信任 AI 原則

Ethics guidelines for trustworthy AI

REPORT / STUDY

Publication 08 April 2019

On 8 April 2019, the High-Level Expert Group on AI presented Ethics Guidelines for Trustworthy Artificial Intelligence. This followed the publication of the guidelines' first draft in December 2018 on which more than 500 comments were received through an open consultation.

According to the Guidelines, trustworthy AI should be:

- (1) lawful - respecting all applicable laws and regulations
- (2) ethical - respecting ethical principles and values
- (3) robust - both from a technical perspective while taking into account its social environment



See also

[A European approach to artificial intelligence](#)

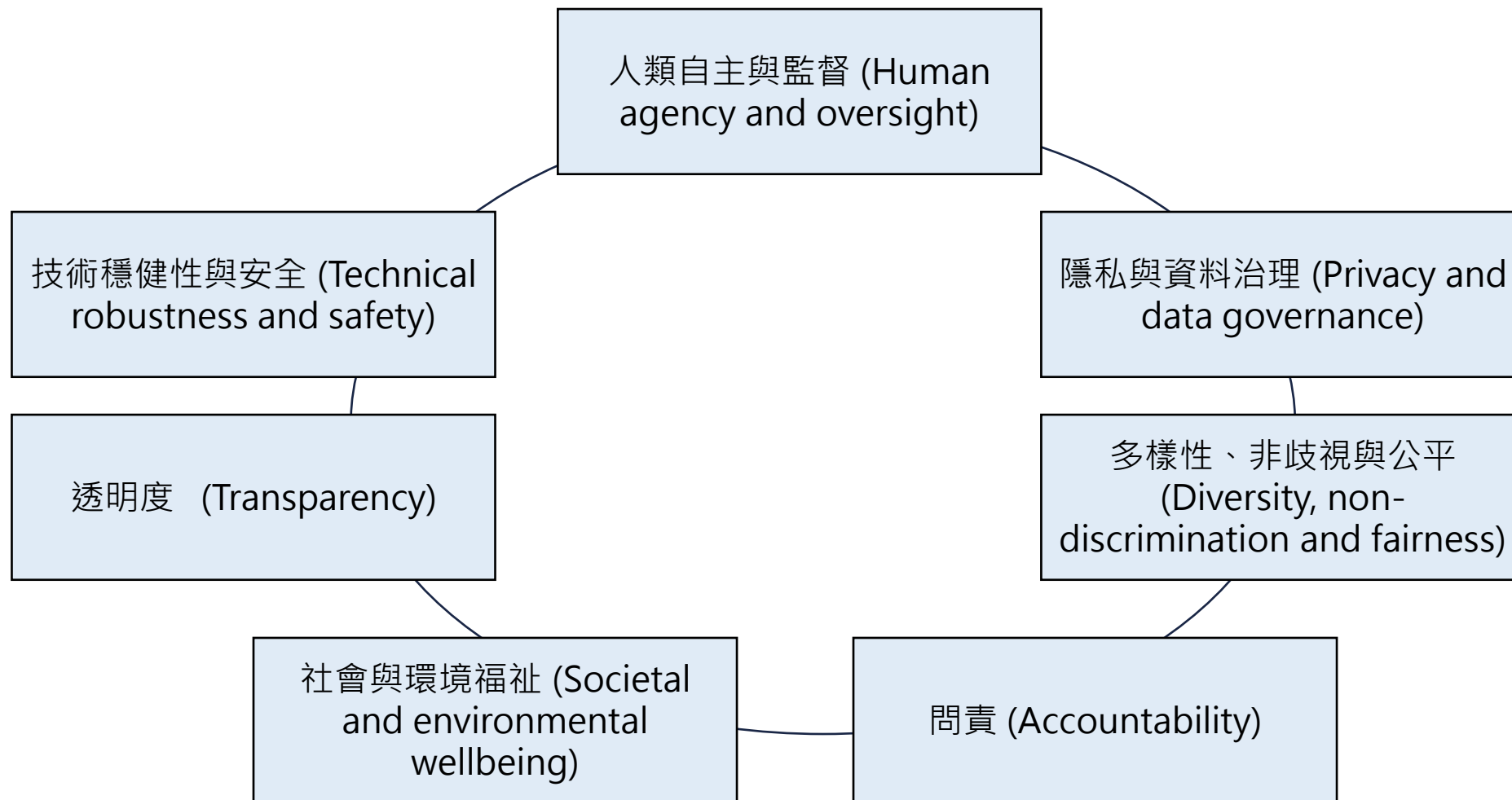
Related topics

[Advanced Digital Technologies](#)

[Artificial intelligence](#)

- 歐盟 2019 年 4 月正式發布 Ethics Guidelines for Trustworthy AI
- 2020 年發布 Assessment List for Trustworthy Artificial Intelligence

歐盟的可信任 AI 的七個要求



可信任 AI 的自我檢查



要求 1：人類自主與監督 (Human Agency and Oversight)

確保 AI 不會削弱人的自主判斷，且人類始終保有必要的監督、介入與控制能力。

要求 2：技術穩健性與安全 (Technical Robustness and Safety)

確保 AI 系統在正常、異常、受攻擊或環境改變時，都能維持安全、準確、可靠且可預期的運作，並能降低非預期傷害。

要求 3：隱私與資料治理 (Privacy and Data Governance)

確保 AI 系統在整個生命週期中，能妥善保護個人隱私與資料權利，並對資料品質、存取、處理與治理建立適當控制。

要求 4：透明度 (Transparency)

確保 AI 系統的運作、決策依據、能力與限制都能被適當理解與追溯，以建立使用者信任並支援後續檢查與申訴。

要求 5：多樣性、非歧視與公平 (Diversity, Non-discrimination and Fairness)

確保 AI 在設計、訓練、部署與使用過程中，不會產生或強化不公平偏誤與歧視，並讓不同背景、能力與需求的使用者都能公平使用。

可信任 AI 的自我檢查 (續)



要求 6：社會與環境福祉 (Societal and Environmental Well-being)
確保 AI 不只對個別使用者有益，也要兼顧環境永續、工作影響、社會整體與民主制度，避免造成長期或系統性傷害。

要求7：問責 (Accountability)
確保 AI 系統在開發、部署與使用過程中，都有明確責任歸屬，且其風險、決策與影響可以被檢查、追溯、審核；若造成不利影響，也要有補救與救濟機制。

美國 NIST AI Risk Management Framework (AI RMF)

平安 (Safe)	有效且可靠 (Valid and Reliable)
安全與韌性 (Secure and Resilient)	公平且妥善管理有害偏誤 (Fair - with Harmful Bias Managed)
可解釋且可理解 (Explainable and Interpretable)	可問責且透明 (Accountable and Transparent)
強化隱私保護 (Privacy-Enhanced)	

- 2020 National Artificial Intelligence Initiative Act 要求 NIST 發展一套可協助組織管理 AI 風險
- 2023/1/26 發布 AI RMF
 - Trustworthiness 不再只是 AI 的「屬性」，而是一個持續管理的結果。
 - 透過治理 → 情境辨識與風險映射 → 衡量 → 風險管理來落實
- 2024/7 NIST AI 600-1 將範圍延伸至生成式 AI
- 2026/4 延伸到關鍵基礎設施與 AI agent/tool

我國的要求

- 人工智慧基本法第四條

- 政府推動人工智慧之研發與應用，應在兼顧社會公益、數位平權、促進創新研發與強化國家競爭力之前提下，發展良善治理與基礎建設，並遵循下列原則：
 - 一、永續發展與福祉：應兼顧社會公平及環境永續。提供適當之教育及培訓，降低可能之數位落差，使國民適應人工智慧帶來之變革。
 - 二、人類自主：應以支持人類自主權、尊重人格權等人類基本權利與文化價值，並允許人類監督，落實以人為本並尊重法治及民主價值觀。
 - 三、隱私保護與資料治理：應妥善保護個人資料隱私，尊重企業營業秘密，避免資料外洩風險，並採用資料最小化原則；同時在符合憲法隱私權保障之前提下，促進非敏感資料之開放及再利用。
 - 四、資安與安全：人工智慧研發與應用過程，應建立資安防護措施，防範安全威脅及攻擊，確保其系統之穩健性與安全性。
 - 五、透明與可解釋：人工智慧之產出應做適當資訊揭露或標記，以利評估可能風險，並瞭解對相關權益之影響，進而提升人工智慧可信任度。
 - 六、公平與不歧視：人工智慧研發與應用過程中，應盡可能避免演算法產生偏差及歧視等風險，不應對特定群體造成歧視之結果。
 - 七、問責：應確保承擔相應之責任，包含內部治理責任及外部社會責任。

條次	內容
§1	立法目的；本法未規定者，適用其他法律之規定
§2	主管機關中央為國科會；地方為地方政府；涉部會職掌為部會
§3	AI定義
§4	AI基本原則
§5	避免AI應用造成違法情事，高風險應用應標示，數發部應提供評估工具
§6	行政院應成立國家AI戰略特別委員會並訂定國家AI發展綱領
§7	持續推動AI與倫理教育
§8	鼓勵人才技術跨域合作與建立基礎設施
§9	寬列AI預算
§10	推動AI研發、應用及基礎建設
§11	扶持AI開發、訓練，並完備AI新創實驗環境
§12	推動國際合作、公私協力
§13	提升AI可利用之資料品質、數量，維繫國家多元文化價值及維護智財權
§14	政府於AI研發及應用過程應保護個人資料
§15	政府應運用AI保障勞工權益，就AI利用所致之失業者應輔導就業
§16	數發部應推動AI風險分類框架，並協助各目的事業主管機關訂定管理規範；並協助產業自訂指引。有§5違法情事者，應依法令限制或禁止
§17	政府應就高風險AI應用明確責任歸屬並建立救濟補償機制。應用前不適用，但在實際環境測試，或提供產品服務時，不在此限
§18	政府應於本法施行後2年內完成法規調適或行政措施之改進
§19	政府公務使用AI應完成風險評估、訂定內控規範
§20	公布日起施行

國家AI戰略特別委員會規劃

召集人
行政院院長

副召集人
行政院副院長

委員

含召集人、
副召集人

執行秘書

行政院政務委員
兼
國科會主任委員

政務委員及相關
機關首長或代表

數發部、國發會、教育部、
經濟部、衛福部、勞動部、
文化部、交通部、金管會、
法務部、督導法務政務委
員、國科會科技辦執秘

學者專家、人工
智慧相關民間團
體及產業代表

直轄市及縣(市)
首長

部會整體作業規劃

國家人工智慧發展綱領（國家人工智慧戰略特別委員會）

確立我國AI發展之核心價值，並指導各部會推動AI發展，確保技術創新、產業發展、社會福祉與人權保障之平衡

共通性創新與人培

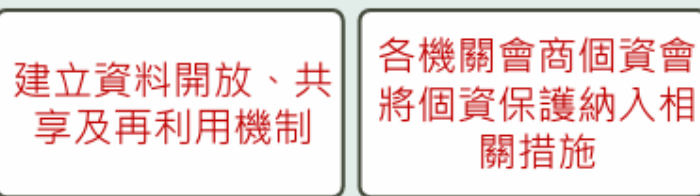


風險管理

AI風險分類框架 評估驗證工具



資料治理



法規調適及業務檢視 (由行政院「數位政策法制協調專案會議」統籌協調)

政府機關內控規範

目的事業風險管理規範

高風險AI應用：
1.明確標示注意事項或警語
2.明確責任歸屬並建立救濟補償保險機制

產業自律規範或指引

促進資料創新利用發展
條例草案

隱私強化技術應用指引

生成式AI
著作權指引

後續推動重點

推動AI風險分類評估(短期)

- 數發部已會同相關機關公告兒少、人權、性別影響評估報告
- 數發部發布「AI風險分類框架」協助各部會針對各領域進行風險評估
- 各機關須完成內部AI應用的情境盤點與風險識別

建立政府內控管理機制 建立資料治理機制(中期)

- 各機關須依風險落實應辦之內控措施
- 訂定「促進資料創新發展條例」

產業風險評估 與產業指引(長期)

各目的事業主管機關，應於2年內視風險管理之需要，訂定風險管理規範，並協助產業訂定指引

主權 AI (Sovereign AI)

- 一個國家或組織能夠在自身可控制的法律、資料、算力、模型、人才與營運環境下，獨立發展、部署與治理 AI 的能力。
- 沒有主權 AI 的情況：
 - 政府或關鍵機構使用境外雲端 AI 服務，若其資料處理、模型決策或安全事件發生在境外，本國主管機關可能難以直接稽核、要求揭露、執行處分或強制改善。
 - 敏感資料可能外流至境外、受外國司法管轄，或被用於模型訓練與二次利用，導致資料控制權下降。
 - 過度依賴少數海外 GPU、雲端或資料中心，一旦供應鏈中斷、價格上漲或被限縮，就無法自主維持 AI 能力。
 - 政府把重要決策支援系統建立在封閉式外國模型上，供應商突然改版後，輸出行為改變，但使用單位無法控制或回復到舊版本。
 - 機關採購大型 AI 平台後，所有模型調校、資安修補與異常處理都依靠原廠顧問；一旦服務契約終止，內部幾乎無能力接手。
 - AI 的部署、身分、金鑰、監控、更新與故障處置都由外部平台掌握，難以保證業務持續性與自主控制。
- 結果就是：法律受制、資料失控、算力受限、模型受制、人才空洞、營運中斷

我國的作法

- 由人工智慧基本法第六條建立治理框架：
 - 行政院應成立國家人工智慧戰略特別委員會，由行政院院長召集學者專家、人工智慧相關民間團體及產業代表、政務委員、相關機關首長或代表、直轄市及縣（市）政府首長組成，協調、推動及督導全國人工智慧事務，並訂定國家人工智慧發展綱領。前項委員會每年至少召開會議一次，並審議國家人工智慧發展綱領；遇突發緊急或重大事件，應召開臨時會議。第一項委員會之幕僚作業，由國家科學及技術委員會辦理。
- 就 AI 新十大建設文件中，主權AI及算力建設主權算力部分，可以分成：
 - 算力自主：國家級 AI 算力、雲端開發環境、公私算力聯盟
 - 技術自主：基礎模型、關鍵演算法、AI 應用系統
 - 資料自主：主權 AI 語料庫、臺灣語言文化資料、授權機制
 - 安全自主：AI 威脅分析、預警、根因判別與資安韌性

不是所有 AI 都要國產，而是要掌握關鍵的算力、模型技術、訓練資料與安全防禦能力。

https://www.ndc.gov.tw/Content_List.aspx?n=EF80A54FA6A63200

金融業運用人工智慧(AI)指引

- 金融監督管理委員會 2024 年 6 月發布
- 基於「金融業運用人工智慧(AI)核心原則與相關推動政策」

總則章 共通事項

第一章 建立治理及問責機制

第二章 重視公平性及以人為本的價值觀

第三章 保護隱私及客戶權益

第四章 確保系統穩健性與安全性

第五章 落實透明性與可解釋性

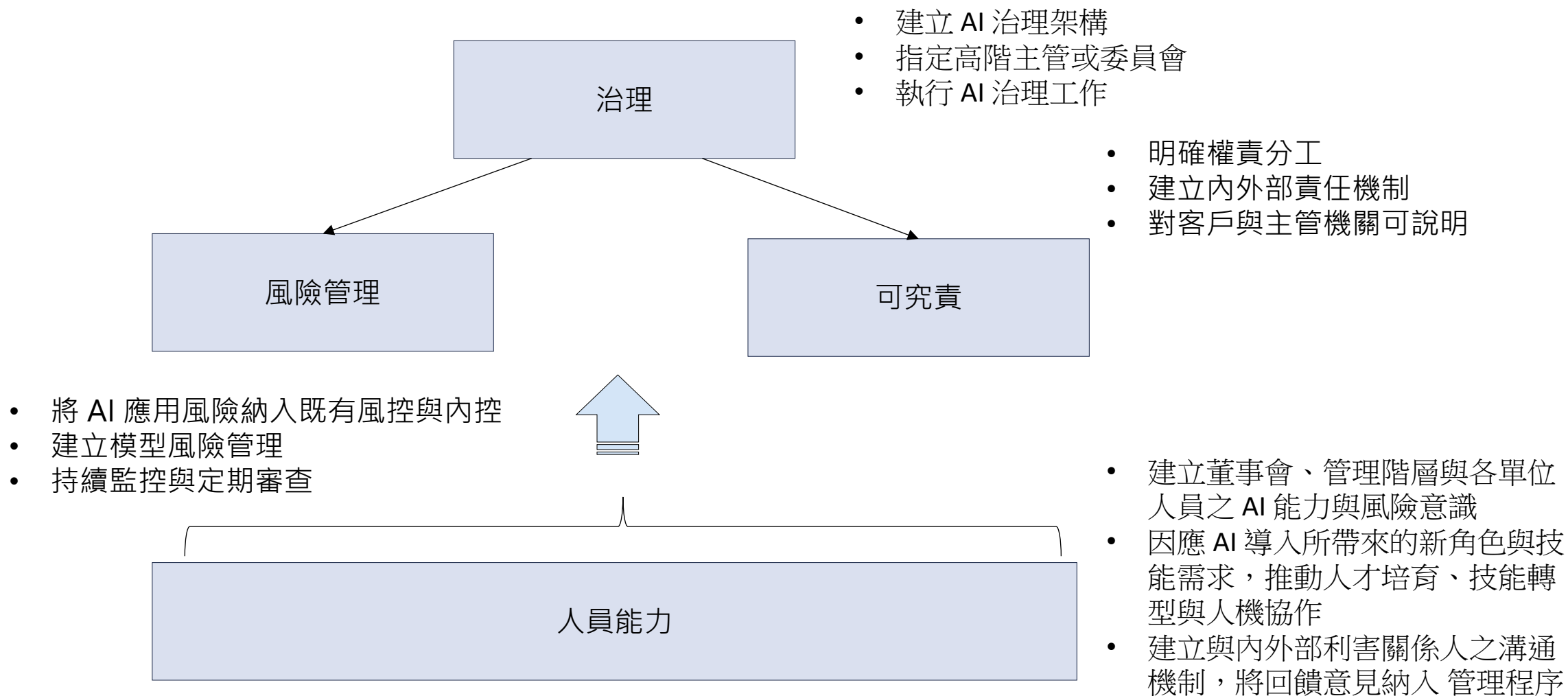
第六章 促進永續發展

總則章

- 人工智慧相關定義
- AI 系統生命週期
- 風險評估考量因素
- 以風險為基礎落實核心原則
- 第三方業者之監督管理



建立「有主管負責、有制度管理、有風險控制、有人才能力」的 AI 治理體系



重視公平性及以人為本的價值觀

- 金融機構應避免：
 - 演算法偏見 (Bias)
 - 差別待遇 (Discrimination)
 - 不合理決策
- 不見得要求AI 一定完全公平，而是要求能夠持續識別、監控、改善偏見
- 人類監督
 - 人類主導 (Human-in-Command, HIC)
 - 人類核准後執行 (Human-in-the-Loop, HITL)
 - AI 自動執行，人類監看 (Human-over-the-Loop, HOTL)
- 對於高風險應用，應優先採用人類主導或人類核准後執行
- 即使使用第三方生成式 AI，金融機構仍須對 AI 產出內容負責。
- 確保 AI 決策公平、可受人類監督且維持最終人類控制權，避免偏見、歧視及失控風險。
- AI 可以協助決策，但責任不能委託給 AI；必須確保決策公平、可監督且可控。

保護隱私及客戶權益

隱私保護

- 保護客戶個資、營業秘密與敏感資訊
- 降低資料外洩與未授權存取風險
- AI 應符合個資法及相關規範

資料治理

- 採取資料最小化原則
- 確保資料來源合法、正確且完整
- 建立資料保護與供應鏈管理機制

客戶選擇權

- 告知客戶服務涉及 AI
- 提供必要資訊協助理解 AI 決策
- 評估是否提供非 AI 替代方案

- 金融機構人員不得在缺乏適當管控機制下：
 - 將客戶資料輸入公開生成式 AI
 - 將未經同意之客戶資訊提供給生成式 AI
- 確保 AI 的資料使用合法、安全且符合客戶意願，並避免因 AI 導致個資外洩或客戶權益受損。

確保系統穩健性與安全性

穩健性

確保 AI 能夠：

- 穩定運作
- 正確決策
- 可重複驗證
- 即使面對異常輸入、壓力情境、環境變化等情況仍能維持預期功能。

模型可靠性

金融機構應：

- 明確定義 AI 目標
- 建立衡量指標
- 進行模型驗證
- 執行交叉驗證
- 執行對抗性測試
- 持續監控模型漂移

資安防護

建立 AI 全生命週期安全機制：

- 資料保護
- 模型保護
- Prompt 保護
- API 保護
- 基礎設施保護

第三方風險

若進行委外，供應商金融機構仍須：

- 評估供應商安全性
- 持續監督
- 留存紀錄
- 驗證安全控制措施

- 確保 AI 系統在面對錯誤、攻擊或環境變化時，仍能持續、安全且可靠地運作。

落實透明性與可解釋性

透明性

讓利害關係人知道：

- AI 是否參與決策
- AI 的用途與限制
- AI 可能帶來的影響

可解釋性

金融機構應能說明：

- AI 如何運作為何
- 做出該決策
- 哪些因素影響結果

文件化與可追溯

建立完整紀錄，確保 AI 決策可被追蹤與驗證。

溝通與揭露

金融機構應建立：

- 客戶說明機制
- 客服與客訴流程
- 對監理機關

說明能力但也須平衡，避免過度揭露。

- 確保 AI 的運作與決策過程可被理解、解釋與追溯，並在適當範圍內向客戶及監理機關揭露。

促進永續發展

環境永續

降低 AI 帶來的資源消耗：

- 降低能源消耗
- 提升運算效率
- 優化模型複雜度
- 提升硬體使用效率

社會共融

避免 AI 導致新的不平等。

並關注：

- 普惠金融
- 數位落差
- 數位焦慮

員工轉型

AI 不只是取代工作。金融機構應：

- 協助員工技能升級
- 強化 AI 素養
- 支持新工作模式
- 推動人機協作

永續策略整合

金融機構應將 AI 納入：

- ESG
 - 永續發展目標
 - 企業社會責任
- 評估 AI 對：環境、社會、治理的整體影響

- 確保 AI 發展兼顧環境永續、社會共融與員工轉型，創造長期且負責任的數位競爭力。

金融機構運用人工智慧技術作業規範

- 「金融業運用人工智慧 (AI) 指引」偏向治理原則，而「金融機構運用人工智慧技術作業規範」偏向實務控制措施；
 - 兩者互補，但並非嚴格的一一對應的上下位規範。

條次	重點
第1條	制定目的：強化 AI 應用之客戶資料保護、風險控管與銀行業務管理。
第2條	AI 與生成式 AI 定義：明確界定 AI 與 GenAI 的範圍。
第3條	風險評估適用範圍：涉及客戶權益或重大營運影響的 AI 應進行風險評估。
第4條	永續發展：AI 策略應結合 ESG 與永續目標。
第5條	法規遵循：遵循資安、個資、智慧財產權等相關法規。
第6條	公平待客：避免演算法偏見與歧視，並納入公平待客原則。
第7條	模型品質管理：重視資料品質、模型驗證、可靠性及可解釋性。
第8條	資訊安全與隱私：保護資料、模型及系統，防止資料外洩與攻擊。

條次	重點
第9條	治理與人才：指定高階主管或委員會，建立治理架構並推動人才培育。
第10條	文件化與第三方管理：保存技術文件，管理第三方 AI 並明確責任。
第11條	客戶告知義務：AI 服務應揭露 AI 參與，並提供選擇權與替代方案。
第12條	導入前評估：部署前應評估資料治理、資安、監督機制及應變措施。
第13條	風險管理與獨立評估：建立風險管理機制，必要時由第三方評估；GenAI 輸出仍須由金融機構負責。
第14條	AI 委外管理：涉及 AI 作業委外時，應遵循金融機構委外管理規範。
第15條	內控內稽：將 AI 納入內部控制及內部稽核，並定期查核
第16條	施行政程序：規範之訂定與修正程序。



國家標準(CNS)網路服務系統

本服務系統為經濟部標準檢驗局依「政府採購法」評選委託優勝廠商中華電信(股)資訊技術分公司建置、營運及銷售

※列印之標準如需加蓋正本文件證明章，或購買大尺寸及彩色版標準，請洽櫃檯客服人員！

查詢標準請確認版次，若欲查詢舊版次標準資料，請點選「舊版標準」選項，或請電洽 02-23431980。

[網站導覽](#)
[各期電子報](#)
Language ▼

[首頁](#)
[檢索](#)
[舊版標準](#)
[購買說明](#)
[電子報](#)
[正字標記](#)
[與我聯絡](#)
[相關網站](#)
[網站導覽](#)
[幫助](#)
[操作手冊](#)
[分類目錄](#)

國家標準公告

- 標準局 112/08/30 新公告已可線上查詢與付費下載 2023/09/13
- 標準局 112/08/30 新公告：最新制定 13 種國家標準、修訂 2 種國家標準、廢止 23 種國家標準公告 2023/09/07

[+ 更多...國家標準公告](#)

CNS相關新聞稿

- 為因應年長者或身心障礙者步行之需求，經濟部標準檢驗局制定「步行推車」國家標準 2023/06/30
- 標準局打造優質兒童用品消費環境，參考ISO國際標準及歐盟標準，公布2部「手推嬰幼兒車」標準 2022/12/07

CNS 年繳會員登入

ntustcns

洽購CNS櫃檯服務

電話: +886 2 23414772
電話: +886 2 23431994

傳真: +886 2 8192-6746

電子信箱: cnsonline@hibox.hinet.net

服務時間：週一至週五
8:30AM~5:30PM
非上班時間：請撥打0800080412

← ISO/CASCO

Documents

Parent folder

09. ISO Survey of certifications to management system standards - Full results

↓ Title ↑

Modified

Folder Past Surveys

2022-09-15

↓ 0.Explanatory note and overview on ISO Survey 2022 results

2023-09-12

↓ 3.ISO Survey 2022 - comparison with 2021 - using data from providers taking part both years

2023-09-12

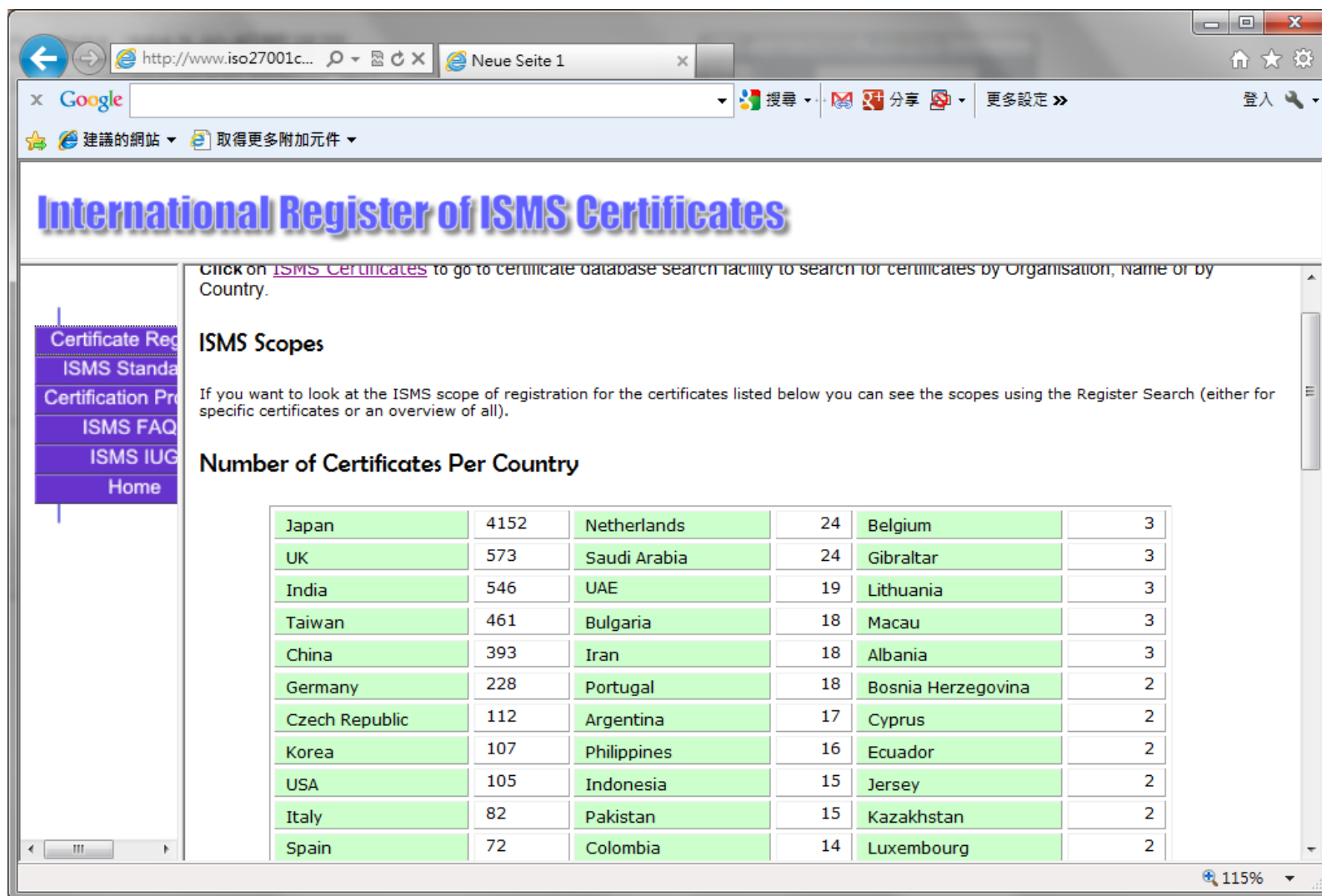
↓ 1.ISO Survey 2022 results - Number of certificates and sites per country and the number of sector overall

2023-09-12

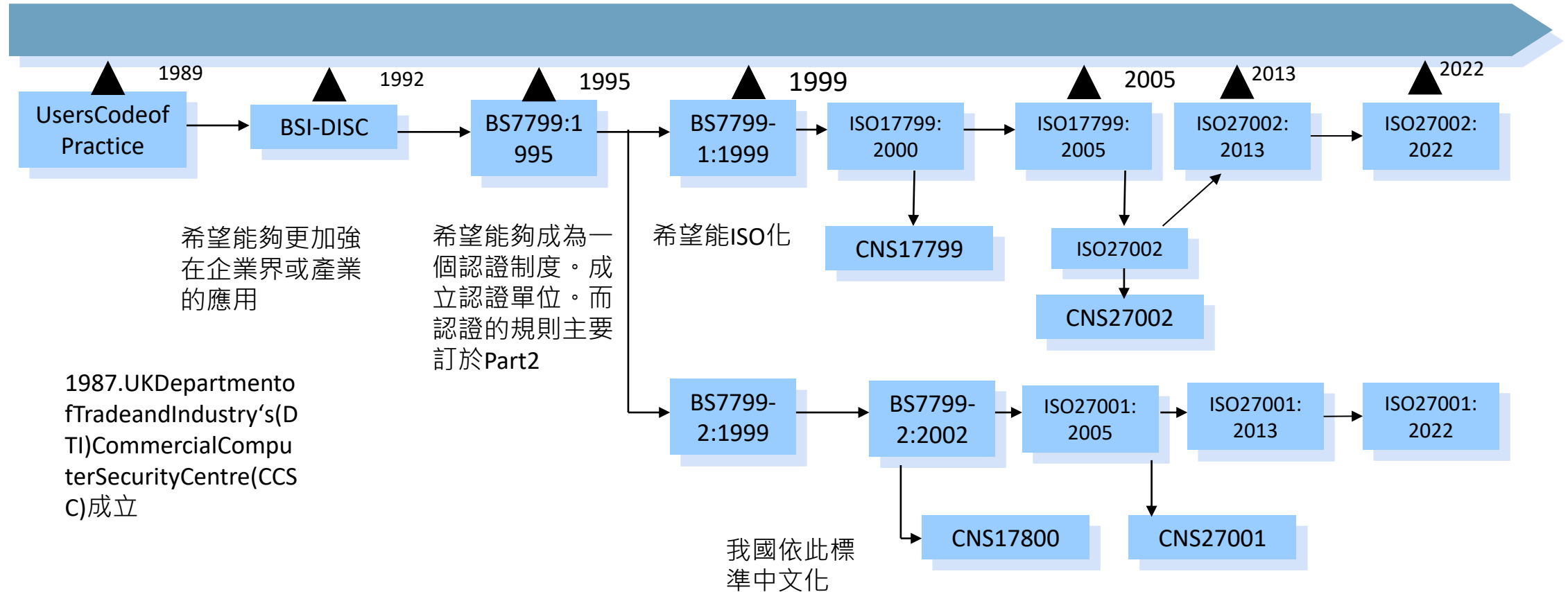
↓ 2. ISO Survey 2022 results - Number of sectors by country for each standard

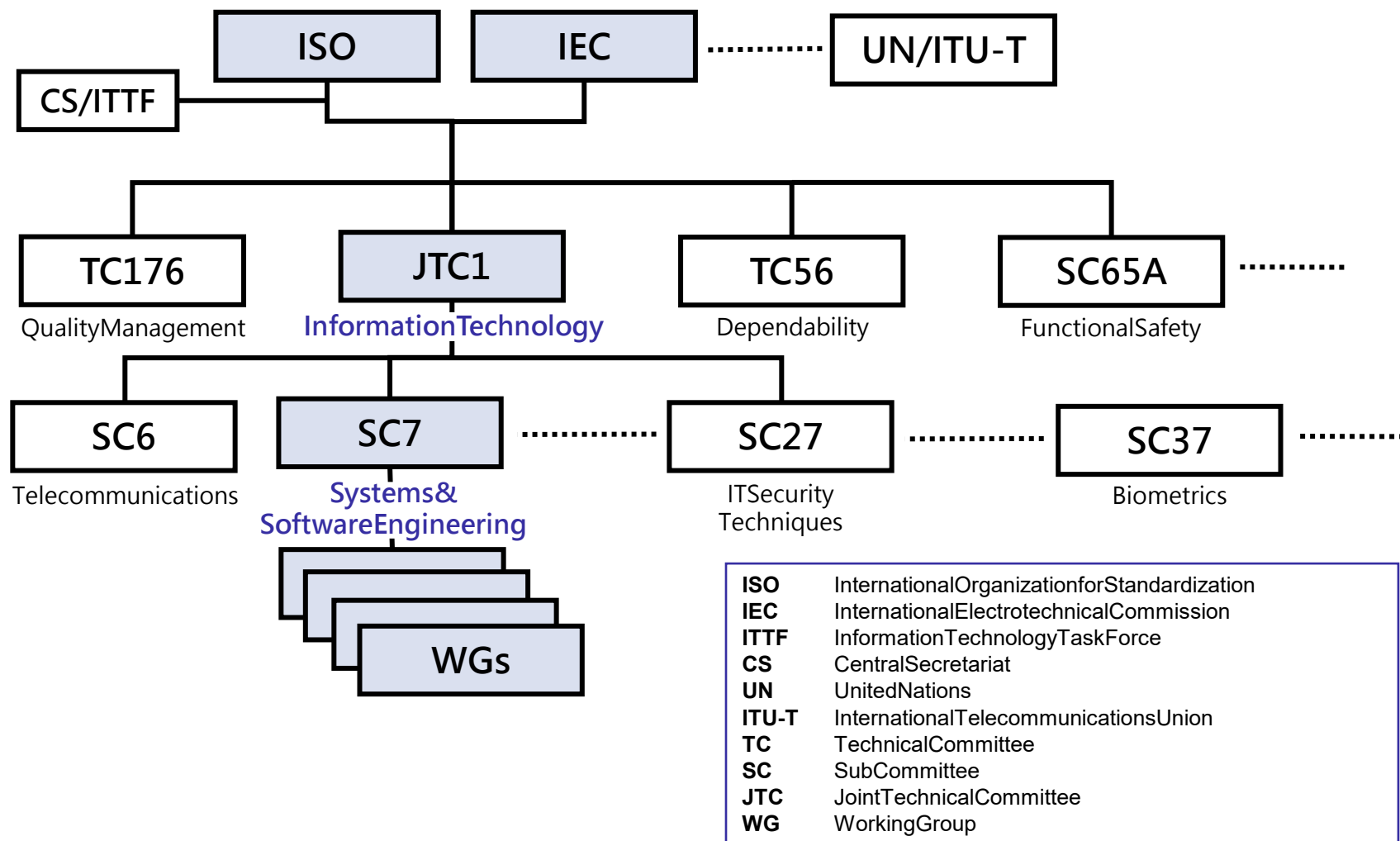
2023-09-12

看瀏覽器就知道很久以前



BS7799/ISO17799/ISO27001資訊安全管理制度





ISO27001:2005→ISO27001:2013改版重點

- 符合ISO Annex SL對於管理制度統一的要求
- 將資安視為公司整體風險的一部分，而用ISO/IEC31000做統一的考量
- 名詞定義引用 ISO/IEC27000
- 更明確的管理階層的支持與承諾要求
- 強調績效展現
- Appendix A. 控制措施的調整
 - 控制領域數：11→14
 - 控制目標數：35→39
 - 控制項目數：133→114

ISO27001:2013→ISO27001:2022改版重點

- 明確要求組織應宣導哪些組織角色和資訊安全相關
- 對於監控資訊安全目標的要求
- 需要了解那些需求或期待要透過ISMS解決
- 要求對於變更進行規劃
- 要求組織說明如何進行傳達或宣導
- 要求建立作業程序目標並設定控制
- 對管理審查項目的新增要求
- 控制措施的調整 (114→93)

組織
人員
實體
技術

如果你有通過 ISO 27701、ISO27017 ,
皮可以繃緊一點

其中也有韌性的概念，在受到干擾時迅速復原
並繼續蓬勃發展。

A.5.7	威脅情資
A.5.23	使用雲端服務的資訊安全
A.5.30	ICT在業務永續中準備就緒
A.7.4	實體安全監控
A.8.9	設定管理
A.8.10	資訊刪除
A.8.11	資料遮罩
A.8.12	資料外洩防護
A.8.16	監控活動
A.8.23	網頁過濾
A.8.28	程式開發時考量安全

ISO Directive Annex SL

- ISO技術管理局委託聯合技術委託小組發展，要求適用之管理制度高階文件標準，應該採用相同的核心結構，包括：

- 0 Introduction

- 1 Scope

- 2 Normative references

- 3 Terms and definitions

- 4 Context of the organization

- 5 Leadership

- 6 Planning

- 7 Support

- 8 Operation

- 9 Performance evaluation

- 10 Improvement

Plan

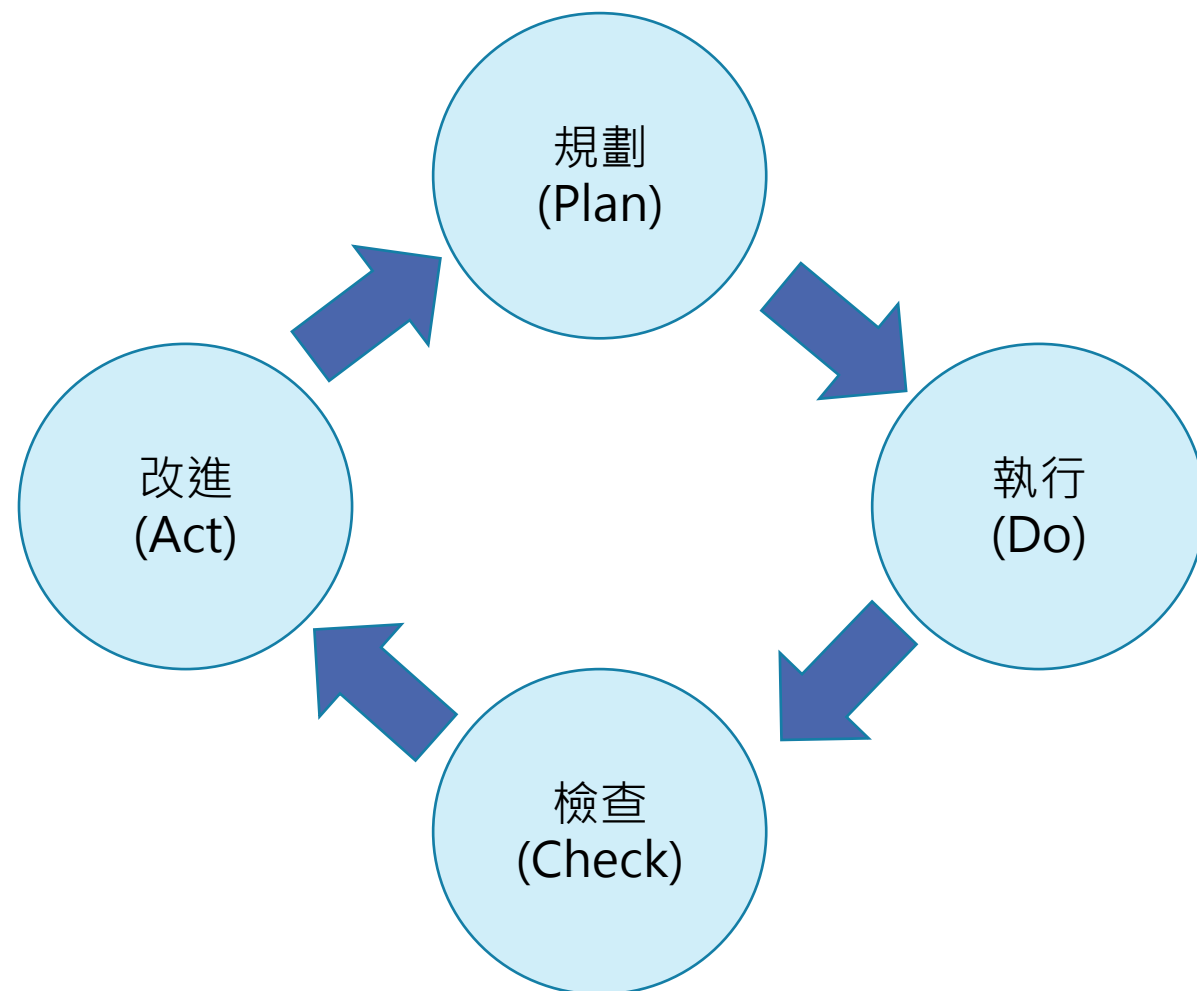
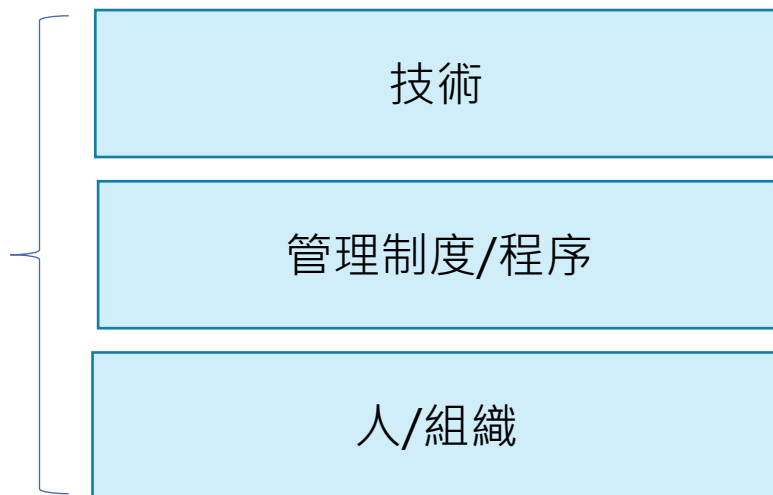
Do

Check

Act

資安管理制度的精神

- 確保人員都知道自己的安全責任
- 確保安全機制的落實
- 透過 PDCA 的循環去確保資訊安全風險有被控管



ISO27001:2022的架構

4組織全景Context of the organization

5領導 Leadership

6規劃 Planning

7支援 Support

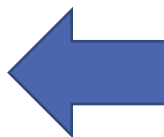
8運作 Operation

9績效評估Performance Evaluation

10改進Improvement

組織全景

- 4.1瞭解組織與其全景
- 4.2了解厲害關係團體的需求與期待
- 4.3決定ISMS範圍
- 4.4資訊安全管理制度



需要了解那些需求或期待要透過ISMS解決

4 組織全景

4.1瞭解組織及其全景

- 組織應決定與其目的有關且影響達成其資訊安全管理系統預期成果能力之外部及內部議題。

4.2瞭解關注方之需要及期望

- 組織應決定下列事項：
 - (a)與資訊安全管理系統有關之關注各方。
 - (b)此等關注方之相關要求事項。
 - (c)此等要求事項中之哪些要求事項，將透過資訊安全管理系統因應。

4.3決定資訊安全管理系統之範圍

- 組織應決定資訊安全管理系統之邊界及適用性，以建立其範圍。於決定此範圍時，組織應考量下列事項：
 - (a)4.1中所提及之外部及內部議題。
 - (b)4.2中所提及之要求事項。
 - (c)組織執行之活動與其他組織執行的活動間之介面及相依性。
- 範圍應以文件化資訊提供。

4.4資訊安全管理系統

- 組織應依本標準之要求事項，建立、實作、維持及持續改善資訊安全管理系統，包括所需過程及其互動。

你是一個三十年經驗的資訊安全經理人員，而且對台灣的資安法規了解甚詳，有一些金融資安的問題要請教



好的，請問您有哪些有關金融資訊安全的問題呢？我很樂意協助您解答。您可以具體描述一下您遇到的挑戰或疑問嗎？

請問有哪些法規符合性的問題



在台灣，金融機構的資訊安全合規性主要受到多項法規的監管，特別是在金融業，要求金融機構在處理客戶資料和敏感數據時，必須嚴格遵守相關的資安規範。以下是幾項重要的法規與合規性問題：

1. 《個人資料保護法》

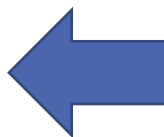
- 這是台灣最重要的資料隱私法之一，適用於所有行業，包括金融業。金融機構必須在蒐集、處理和保存個人資料時，遵守該法對於資料使用的原則，如合法性、特定目的、資料最小化等。
- 企業必須確保個人資料的安全，避免未經授權的存取或洩漏，否則將面臨高額罰款和法律責任。

2. 《金融監督管理委員會》（金管會）的規定

- 金管會針對金融機構設立了一系列資安相關指導原則，要求金融業者建立完善的資安管理機制。例如：
 - 「金融機構資訊安全管理規範」（如金管會法規2019年修正案）：

領導

- 5.1領導與承諾
- 5.2政策
- 5.3組織中角色、責任的定義與授權



明確要求組織應宣導哪些組織角色和資訊安全相關

5 領導

5.1 領導及承諾

最高管理階層應藉由下列事項，展現對資訊安全管理系統之領導及承諾：

- (a)確保已建立資訊安全政策及資訊安全目標，並與組織之策略方向相容。
- (b)確保資訊安全管理系統要求事項整合入組織之各項過程。
- (c)確保資訊安全管理系統所需之資源可取得。
- (d)傳達有效之資訊安全管理的重要性，以及符合資訊安全管理系統要求事項之重要性。
- (e)確保資訊安全管理系統達成其預期成果。
- (f)指導及支援人員，以促進資訊安全管理系統之有效性。
- (g)推動持續改善。及
- (h)當適用其他相關管理角色之責任範圍時，加以支持以展現其領導權。

5.2 政策

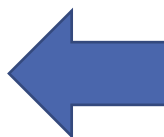
- 最高管理階層應建立包含下列事項之資訊安全政策：
- (a)適合於組織之目的。
- (b)包括資訊安全目標(參照6.2)或提供設定資訊安全目標之框架。
- (c)包括對滿足相關於資訊安全之適用要求事項的承諾。
- (d)包括對持續改善資訊安全管理系統之承諾。
- 資訊安全政策應符合下列項目：
- (e)以文件化資訊提供。
- (f)於組織內傳達。
- (g)適切時，提供予關注方。

5.3組織角色、責任及權限

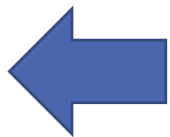
- 最高管理階層應確保資訊安全相關角色之責任及權限已於組織內指派並傳達。
- 最高管理階層應指派下列責任及權限：
- (a)確保資訊安全管理系統符合本標準之要求事項。
- (b)向最高管理階層報告資訊安全管理系統之績效。

6 規劃

- 6.1 因應風險與機會的活動
 - 6.1.1 一般要求
 - 6.1.2 資訊安全風險評估
 - 6.1.3 風險因應
- 6.2 資訊安全目標與達成目標的規劃
- 6.3 對變更的規劃



加了可被監控和可被用文件的方式獲得



這之前沒有

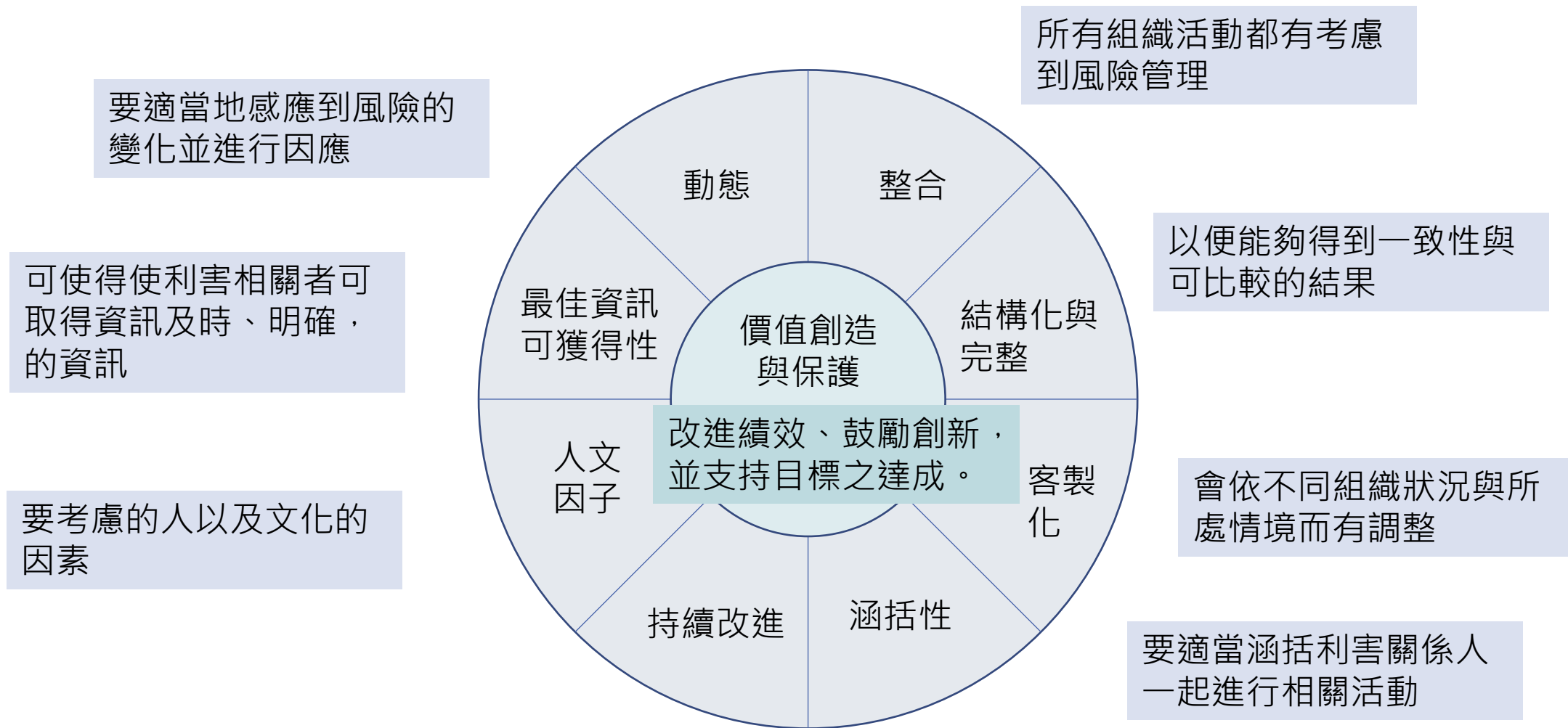
6 規劃

6.1 因應風險及機會之行動

6.1.1 一般要求

- 於規劃資訊安全管理系統時，組織應考量4.1所提及之議題及4.2所提及的要求事項，並決定需因應之風險及機會，以達成下列事項：
- (a) 確保資訊安全管理系統能達成其預期成果。
- (b) 預防或減少非所欲之影響。
- (c) 達成持續改善
- 組織應規劃下列事項：
- (d) 因應此等風險及機會之行動。及
- (e) 執行下列事項之方法：
 - (1) 將各項行動整合及實作於其資訊安全管理系統過程中。
 - (2) 評估此等行動之有效性。

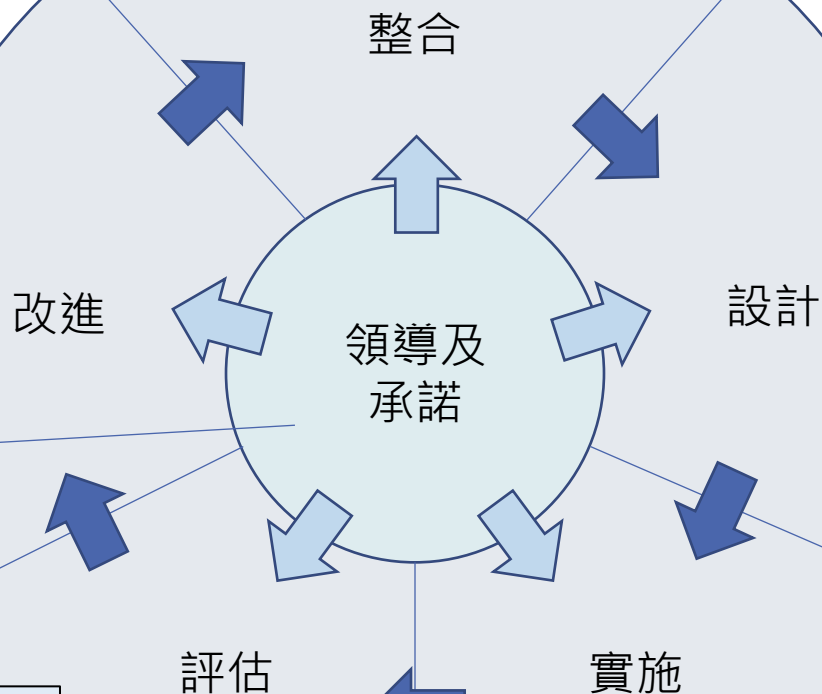
ISO 31000 風險管理原則



風險管理架構

- 將風險管理整合於組織中

- 瞭解組織及其前後環節
- 闡明風險管理承諾
- 分派組織之角色、職權、責任，與做到當責
- 配置資源
- 建立溝通及諮詢



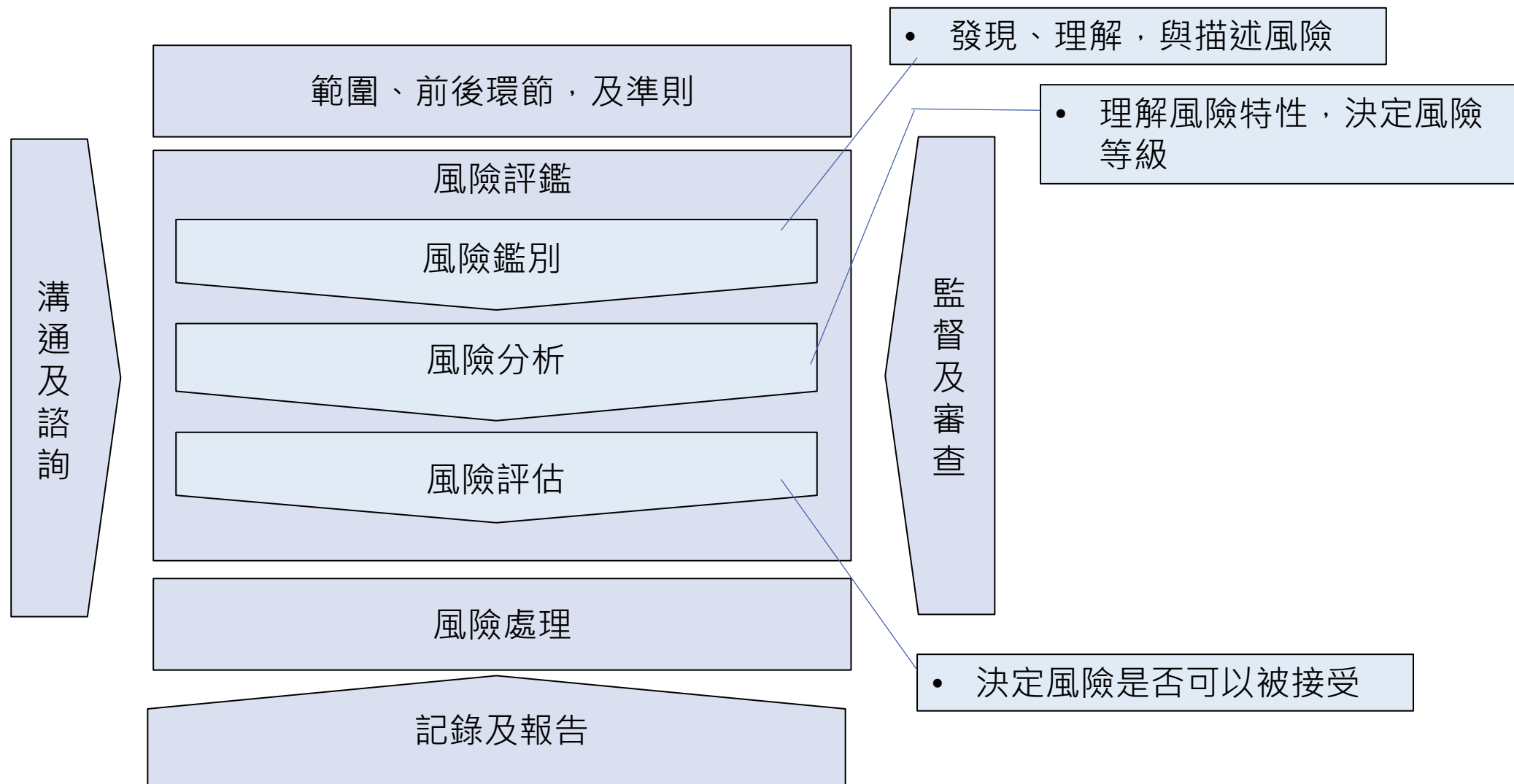
- 最高管理階層與督導機構，如可行時，宜確保將風險管理整合至所有組織的活動

- 評估風險管理架構的有效性

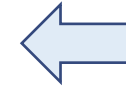
實施風險管理架構：

- 制定適當的計畫，包括時間與資源。
- 鑑別全組織中不同類型的決策於何處、何時、如何及由何人做成的。
- 必要時修改適用的決策訂定過程。
- 確保組織管理風險的安排為清楚可瞭解並實施。

風險管理程序



基本都會考慮到與最佳實務的符合性



如果別人有做某些資安工作，但你沒做，就有可能有沒有考慮到的風險

ISO 27001:2005

資訊資產導向
有效性量測

ISO 27001:2013

企業風險管理

ISO 27001:2022

變更管理

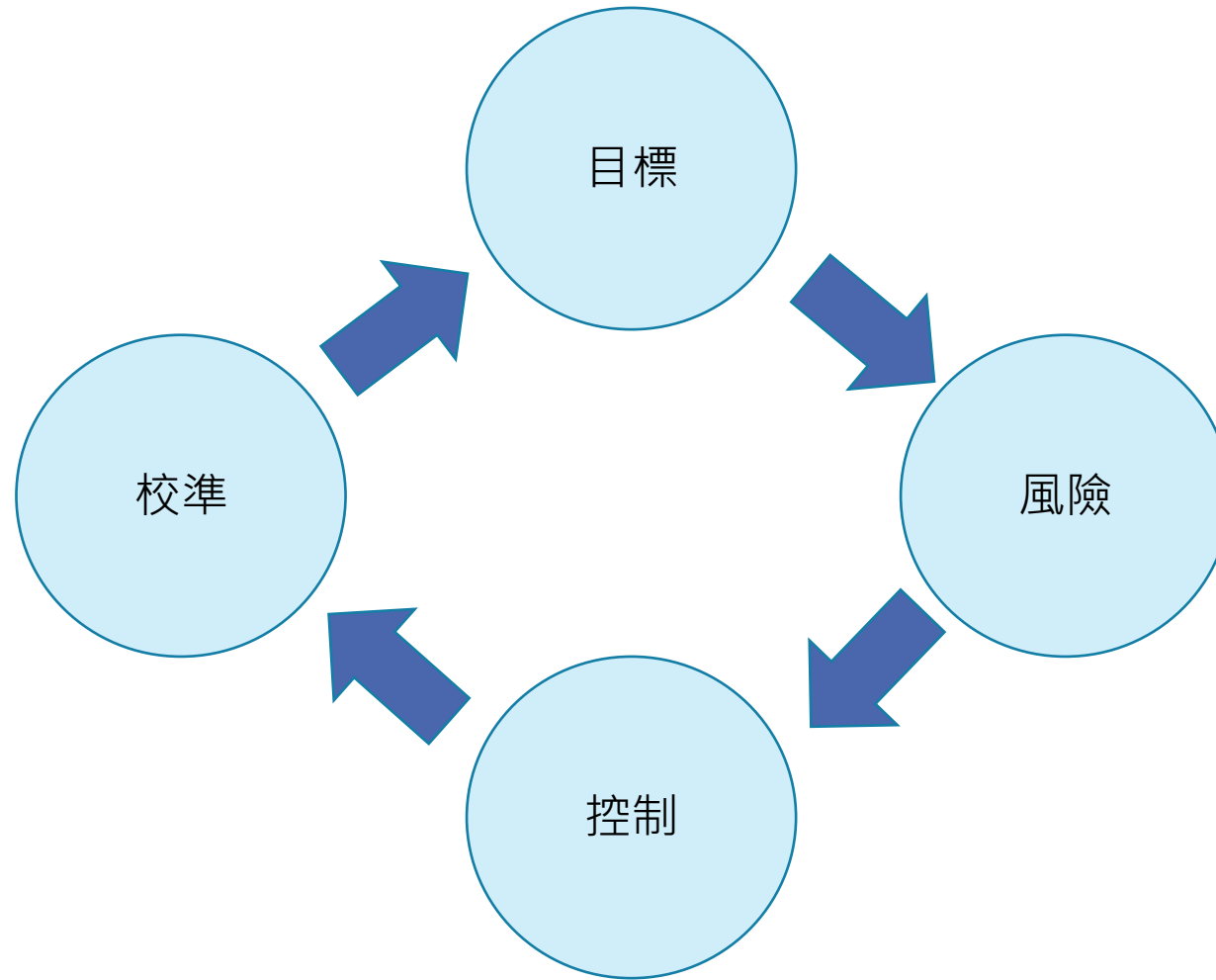
6.1.2資訊安全風險評鑑

- 組織應定義及應用資訊安全風險評鑑過程於下列事項中：
 - (a)建立及維持包括下列準則之資訊安全風險準則：
 - (1)風險接受準則。及
 - (2)執行資訊安全風險評鑑之準則。
 - (b)確保重複之資訊安全風險評鑑產生一致、有效及可比較的結果。
 - (c)識別資訊安全風險：
 - (1)應用資訊安全風險評鑑過程，以識別資訊安全管理系統範圍內與喪失資訊之機密性、完整性及可用性相關聯的風險。及
 - (2)識別風險當責者。
 - (d)分析資訊安全風險：
 - (1)評鑑若6.1.2(c)(1)中所識別之風險實際發生時，可能導致的潛在後果。
 - (2)評鑑6.1.2(c)(1)中所識別之風險發生的實際可能性。及
 - (3)判定風險等級。
 - (e)評估資訊安全風險：
 - (1)以6.1.2(a)中所建立之風險準則，比較風險分析結果。及
 - (2)訂定已分析風險之風險處理優先序。
- 組織應保存關於資訊安全風險評鑑過程之文件化資訊。

6.1.3資訊安全風險處理

- 組織應定義並應用資訊安全風險處理過程，以達成下列事項：
- (a)考量風險評鑑結果，選擇適切之資訊安全風險處理選項。
- (b)對所選定資訊安全風險處理選項，決定所有必須實作之控制措施。
- 備考1.組織可依要求設計控制措施，或由任何來源識別之。
- (c)比較上述6.1.3(b)中所決定之控制措施與附錄A中者，並查證未忽略必要的控制措施。
- (d)產生適用性聲明，包含下列各項：
 - - 必要之控制措施(參照6.1.3(b)及(c))。
 - - 納入之衡量理由。
 - - 是否實作必要之控制措施。及
 - - 排除任何附錄A控制措施之衡量理由。
- (e)制定資訊安全風險處理計畫。及
- (f)取得風險擁有者對資訊安全風險處理計畫之核准，以及對剩餘資訊安全風險的接受。
- 組織應保存關於資訊安全風險處理過程之文件化資訊。

從企業的角度看風險應該著重在對企業目標的影響



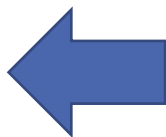
6.2 資訊安全目標及其達成之規劃

- 組織應於各相關部門及層級建立資訊安全目標。
- 資訊安全目標應滿足下列事項：
 - (a)與資訊安全政策一致。
 - (b)可量測(若可行)。
 - (c)考量適用之資訊安全要求事項，以及風險評鑑及風險處理的結果。
 - (d)受監視。
 - (e)被傳達。
 - (f)於適切時，更新之。
 - (g)以文件化資訊提供。
- 組織應保存關於資訊安全目標之文件化資訊。於規劃如何達成資訊安全目標時，組織應決定下列事項：
 - (h)待辦事項。
 - (i)所要求資源。
 - (j)負責人員。
 - (k)完成時間。及
 - (l)結果之評估方式。

- 6.3 變更之規劃
- 當組織決定需要對資訊安全管理系統變更時，應以規劃之方式執行變更

支援

- 7.1資源
- 7.2人員能力的勝任
- 7.3宣導
- 7.4溝通與傳達
- 7.5文件化資訊



要求組織說明如何進行傳達或宣導

7. 支援

7.1 資源

- 組織應決定並提供建立、實作、維持及持續改善資訊安全管理系統所需之資源。

7.2 能力

- 組織應採取下列措施：
 - (a) 決定於組織控制下執行工作，影響其資訊安全績效人員之必要能力。
 - (b) 確保此等人員於適切教育、訓練或經驗之基礎上能勝任。
 - (c) 於適用時，採取行動取得必要能力，並評估所採取行動之有效性。
 - (d) 保存適切之文件化資訊，作為勝任之證據。

7.3 認知

- 於組織控管下，執行工作之人員應認知下列事項：
- (a) 資訊安全政策。
- (b) 其對資訊安全管理系統有效性之貢獻，包括改善的資訊安全績效之益處。及
- (c) 未遵循資訊安全管理系統要求事項之可能後果。

7.4 溝通或傳達

- 組織應決定，相關於資訊安全管理系統之內部及外部溝通或傳達的需要，包括下列事項：
- (a) 溝通或傳達事項。
- (b) 溝通或傳達時間。
- (c) 溝通或傳達對象。
- (d) 溝通或傳達方式。

7.5 文件化資訊

7.5.1 一般要求

- 組織之資訊安全管理系統應包括下列內容：
- (a) 本標準要求之文件化資訊。及
- (b) 由組織所決定對資訊安全管理系統有效性，必要之文件化資訊。
- 備考：各組織之資訊安全管理系統文件化資訊內容，可能因下列因素而異：
- (1) 組織規模，以及其活動之型式、過程、產品及服務。
- (2) 各過程及其互動之複雜度。及
- (3) 人員之能力。

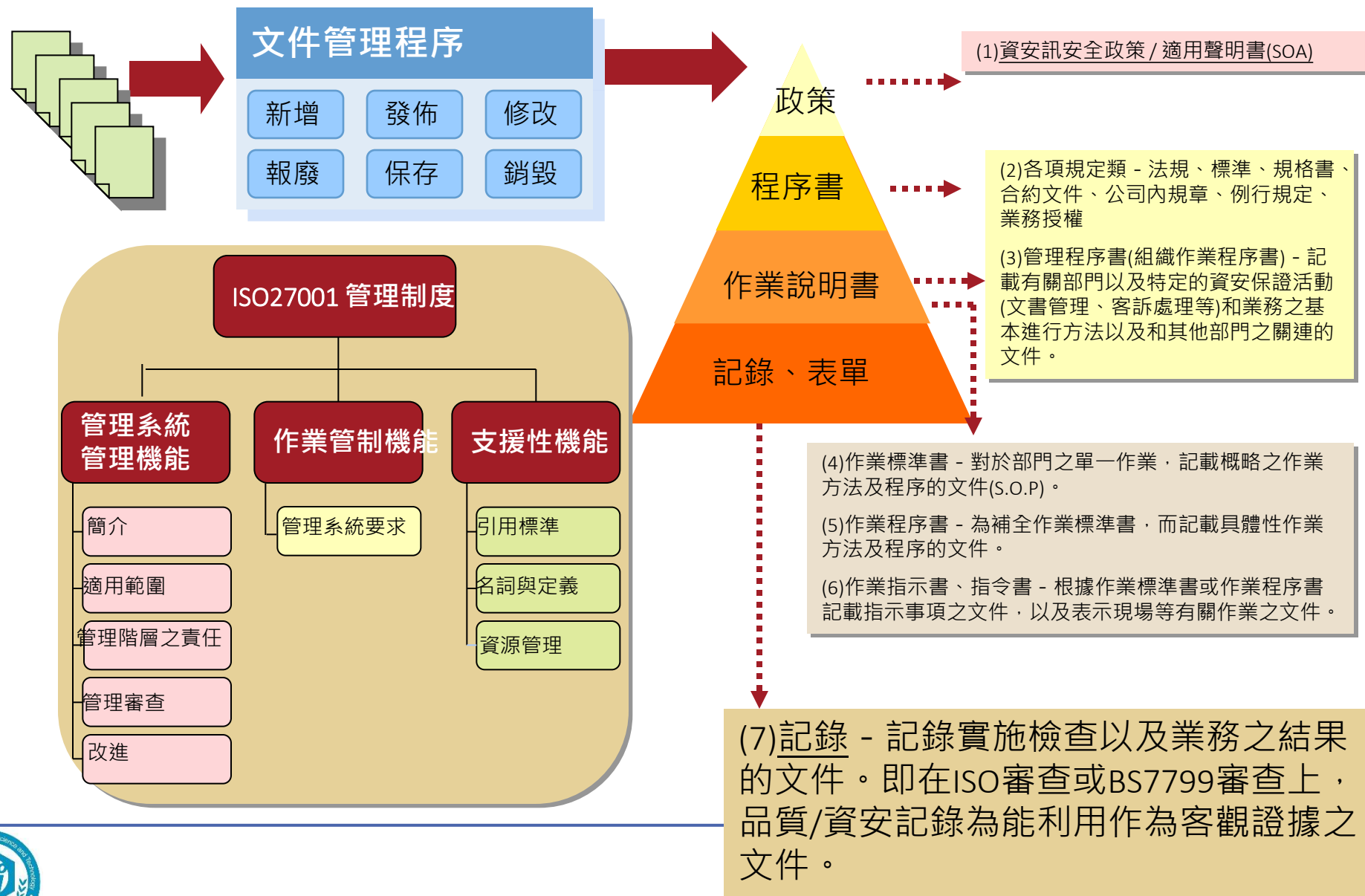
7.5.2 制定及更新

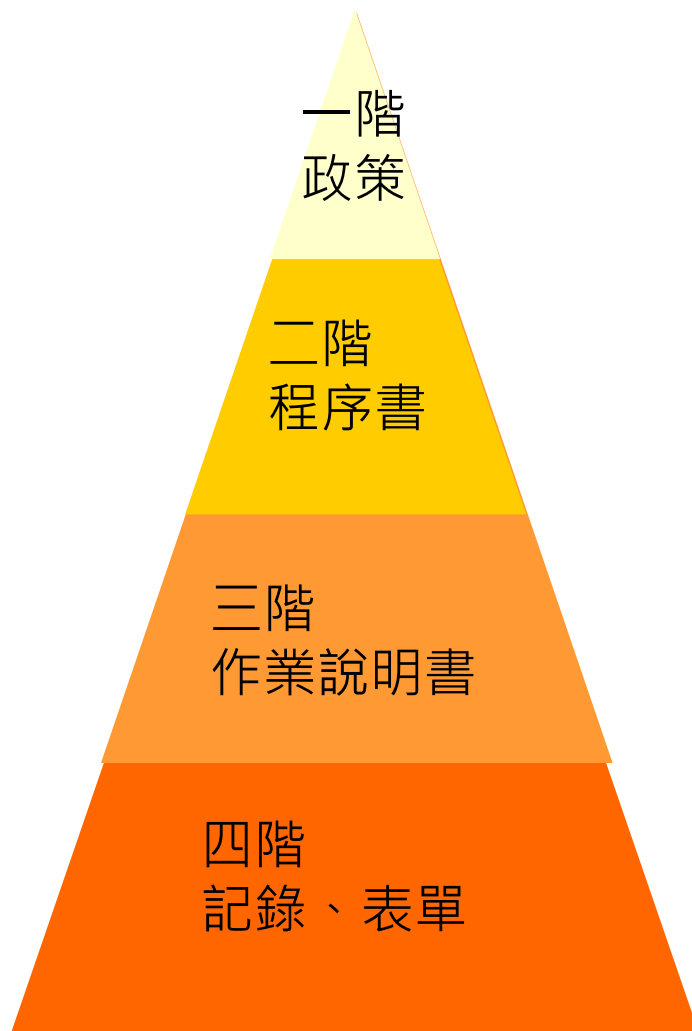
- 於制定及更新文件化資訊時，組織應確保適切之下列項目：
- (a) 識別及描述(例：標題、日期、作者或參引號碼)。
- (b) 格式(例：語言、軟體版本、圖形)及媒體(例：紙本、電子)。及
- (c) 合宜性及適切性之審查及核可。

7.5.3 文件化資訊之控制

- 應控制資訊安全管理系統及本標準要求之文件化資訊，以確保下列事項：
- (a) 其於需要處及需要時為可用及適用。及
- (b) 其受適切保護(例：防止喪失機密性、不當使用或喪失完整性)。
- 為控制文件化資訊，組織應於適用時，闡明下列活動：
- (c) 派送、存取、檢索及使用。
- (d) 儲存及保存，包括可讀性之保存。及
- (e) 變更之控制(例：版本控制)。
- (f) 留存及屆期處置(retention and disposition) 。
- 於適切時，應識別及控制由組織所決定對資訊安全管理系統之規劃及運作為必要之外部來源的文件化資訊。

文件架構之建立





資訊安全政策

資訊安全組織暨職掌分工程序書
委外業務資訊安全規範
文件控管程序書
資訊資產分類暨控管程序書
風險評鑑暨管理程序書
人員安全管理與教育訓練規範
實體及環境安全管理規範

網路安全管理規範
電腦系統安全管理規範
存取控制管理規範
系統發展及維護作業規範
資安事件通報及應變程序書
業務永續運作規範
資訊安全稽核作業規範

三階 作業說明書

委外廠商作業管理工作指導書
資訊資產管理作業指導書
電腦機房管理工作指導書
網路管理工作指導書
電腦設備管理作業指導書
伺服器管理作業指導書

備份工作指導書
資料庫管理作業指導書
各應用系統使用手冊
各應用系統異常事件處理程序書
系統發展與維護工作指導書
異常事件通報處理工作指導書

四階 記錄、表單

標誌

文件標題

機密等級

狀態

文件編號

初版發行日期

修訂發行日期

標誌

機密等級

頁首

文件名稱

文件編號

歷次變更記錄

文件保管人
文件發行方式

頁尾

版權聲明

頁數/總頁數

標誌	頁首	文件名稱
機密等級		文件編號
目錄		
1. 說明		
1.1 目的		
1.2 範圍		
1.3 定義		
2. 權責		
3. 控制重點		
4. 作業程序		
5. 參考文件		
附錄		
頁尾		
版權聲明		
頁數/總頁數		

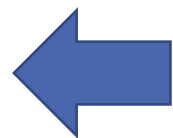
新增	發佈	修改
報廢	保存	銷毀

作業

8.1 作業規劃與控制

8.2 資訊安全風險評估

8.3 資訊安全風險因應



加入程序標準或目標的要求，並且說控制必須基於目標

8. 作業

8.1 運作之規劃及控制

- 組織應規劃、實作及控制符合要求事項所需之過程，並藉由下列方式，實作第6節中所決定的行動：
 - 建立過程之準則。
 - 依準則實作過程之控制措施。
- 應保存應提供文件化資訊，其程度須具足以達成其過程已依規劃執行之信心。
- 組織應控制所規劃之變更，並審查非預期變更的後果，必要時採取行動以減輕任何負面效果。
- 組織應確保與資訊安全管理系統相關外部所提供之過程、產品或服務受控制。

8.2 資訊安全風險評鑑

- 組織應依規劃之期間，或當提議或發生重大變更時，考量6.1.2(a)所建立之準則，執行資訊安全風險評鑑。
- 組織應保存資訊安全風險評鑑結果之文件化資訊。

8.3 資訊安全風險處理

- 組織應實作資訊安全風險處理計畫。
- 組織應保存資訊安全風險處理結果之文件化資訊。

想一想

- 為何建 SOP 會須要有文件化的程序？
- 甚麼是四階文件的概念？
- 如何證明程序有落實？

以資安中心建立軟體安全檢測服務為例—目標

編號	項目	說明
O1	能夠有效辨識軟體當中的弱點	此處所謂有效，主要是指所提交的弱點的誤報率可被控制在某一個程度底下，並且漏報率應接近於零。
O2	能夠協助受檢方避免程式安全弱點	能夠在檢測報告中呈現具體資訊，而能夠協助委託方理解弱點的成因，並且對弱點進行修補。
O3	能夠有效率的完成檢測工作	能夠在預定的時間內完成檢測工作。
O4	避免重要機敏資料外洩	能夠保護受檢方所提供的機敏資料，避免因資料外洩而造成損失或委託方的不信任。
O5	能夠提供使委託方滿意之服務	委託方對於檢測服務之服務品質滿意。

以資安中心建立軟體安全檢測服務為例－風險與控制措施

檢測目標	風險項目	控制措施
能夠有效辨識軟體當中的弱點	R11: 檢測工具無法掃描受檢原始碼	C1、C2
	R12: 檢測工具未更新，以致未能發現最新網頁應用程式安全弱點	C1、C2、C3
	R13: 檢測人員疏忽或能力不足，未能正確操作工具	C3
	R14: 檢測人員疏忽或能力不足，未能正確指出弱點	C2、C4、C5
能夠協助委託方避免程式安全弱點	R21: 檢測人員能力不足，無法提出有效解決方式	C4
能夠有效率的完成檢測工作	R31: 檢測工具無法掃描受檢原始碼	C1、C2、C8
	R32: 檢測人員能力不足，無法準時交付檢測結果	C2、C4
避免重要機敏資料外洩	R41: 檢測人員故意或非故意洩漏受檢程式相關機敏資訊	C6、C7
	R42: 駭客或未經授權人員存取機敏資料	C7
能夠提供使委託方滿意之服務	上述各項風險皆有可能導致此目標無法達成	C1、C2、C3、C4、C5、C6、C7、C8、C9

控制措施

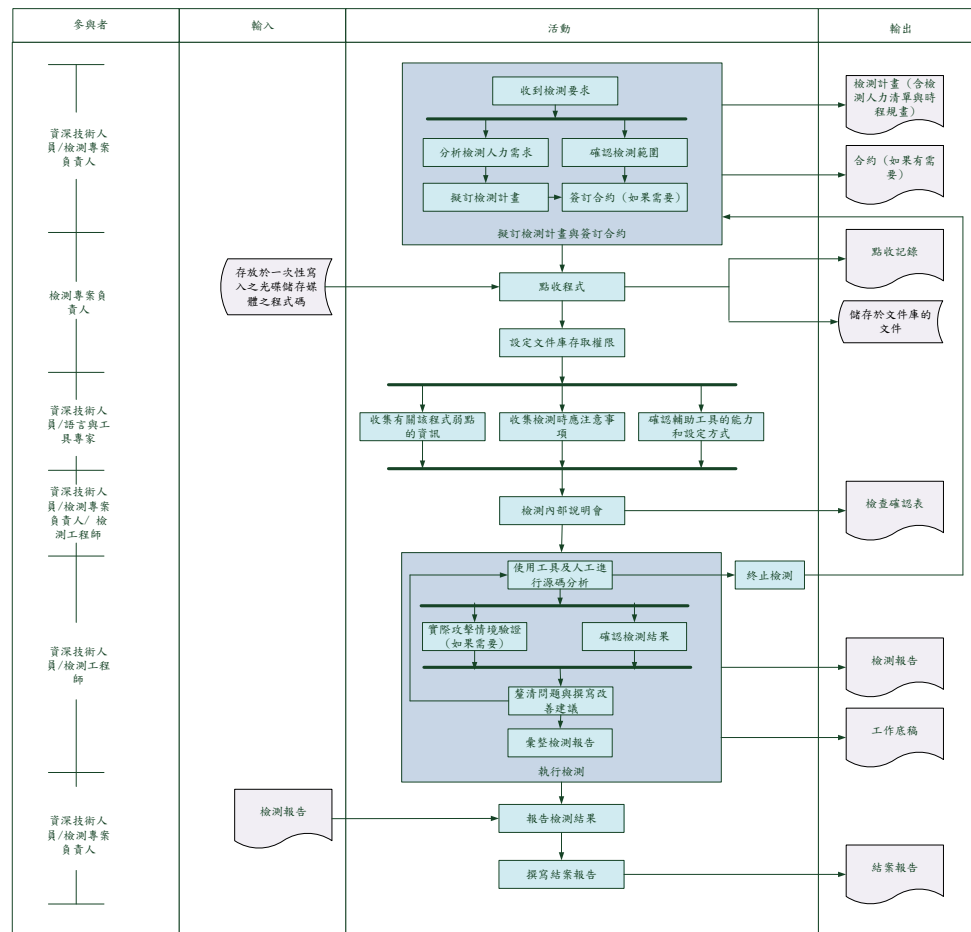
控制項	說明	所在程序
C1	檢測前工具調校或定期更新與維護，確保檢測工具的支援能力能有效協助檢測	於「人員管理程序」，要求指派工具負責人進行相關工作。
C2	指派負責人搜尋最新軟體安全弱點及解決方法，確保檢測人員能夠及時發現最新的軟體安全弱點	於「人員管理程序」，要求負責人，對於各項可用做網站應用程式開發之程式語言進行追蹤，以掌控最新之弱點。
C3	指派負責人熟悉檢測工具，並維持檢測工具之更新	於「人員管理程序」要求指派工具負責人進行相關工作，並規畫教育訓練，以確保檢測人員熟悉工具。
C4	檢測人員教育訓練及考核，確保檢測人員熟知所有軟體安全弱點	於「人員管理程序」中，要求檢測人員通過基本網頁應用程式安全弱點能力檢定。而在執行檢測時，也要確保參與人員皆有通過檢定。
C5	檢測工作底稿覆核及動態測試驗證，降低檢測誤報率，確保檢測服務品質	於「網站應用程式安全檢測程序」中，要求所有的檢測結果要經過覆核。

控制措施

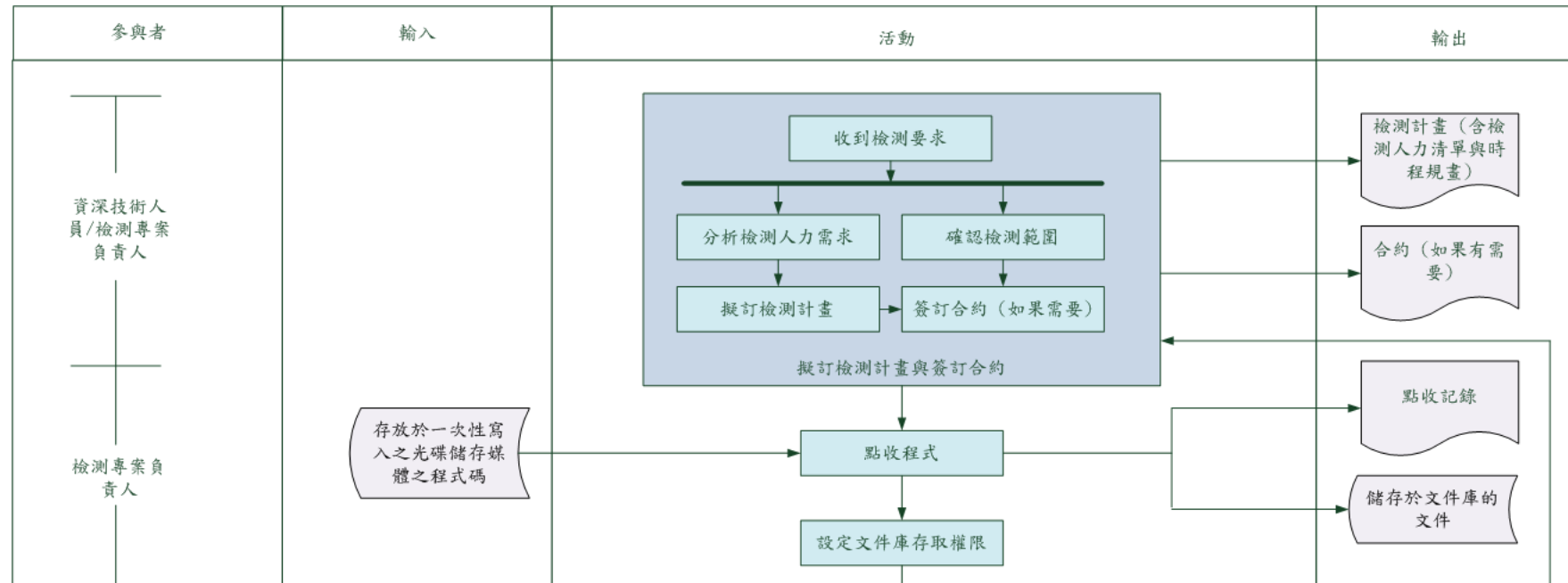
控制項	說明	所在程序
C6	可能接觸受檢程式及其他程式相關文件者，均需簽署保密協議，確保檢測人員不會洩漏機敏資料	於「網站應用程式安全檢測程序」中，要求所有檢測人員簽署保密協議。
C7	設定文件存取權限，並注重重要機敏資料管控，確保機敏資料無法遭受未經授權的存取	除了對於機敏資料的存取加以控管外，也建立「資訊安全管理程序」，以保護機敏資料。
C8	對於檢測工具與相關設備做好設定與業務永續運作管理	分別於「軟體應用安全檢測組態管理程序」、「變更管理程序」、「事故暨問題管理程序」、「業務永續管理程序」建立相關規範，以降低意外事件發生的可能性，並在意外事件發生時管控損失，並能儘快回復工具之正常運作。
C9	檢測專案前應簽署服務水準協定，以便使委託方對於檢測服務品質有合理的期待。	於「網站應用程式安全檢測程序」中，要求接受檢測委託時，依照「服務水準管理程序」，與委託人談妥服務水準。

指標 (供校準使用)

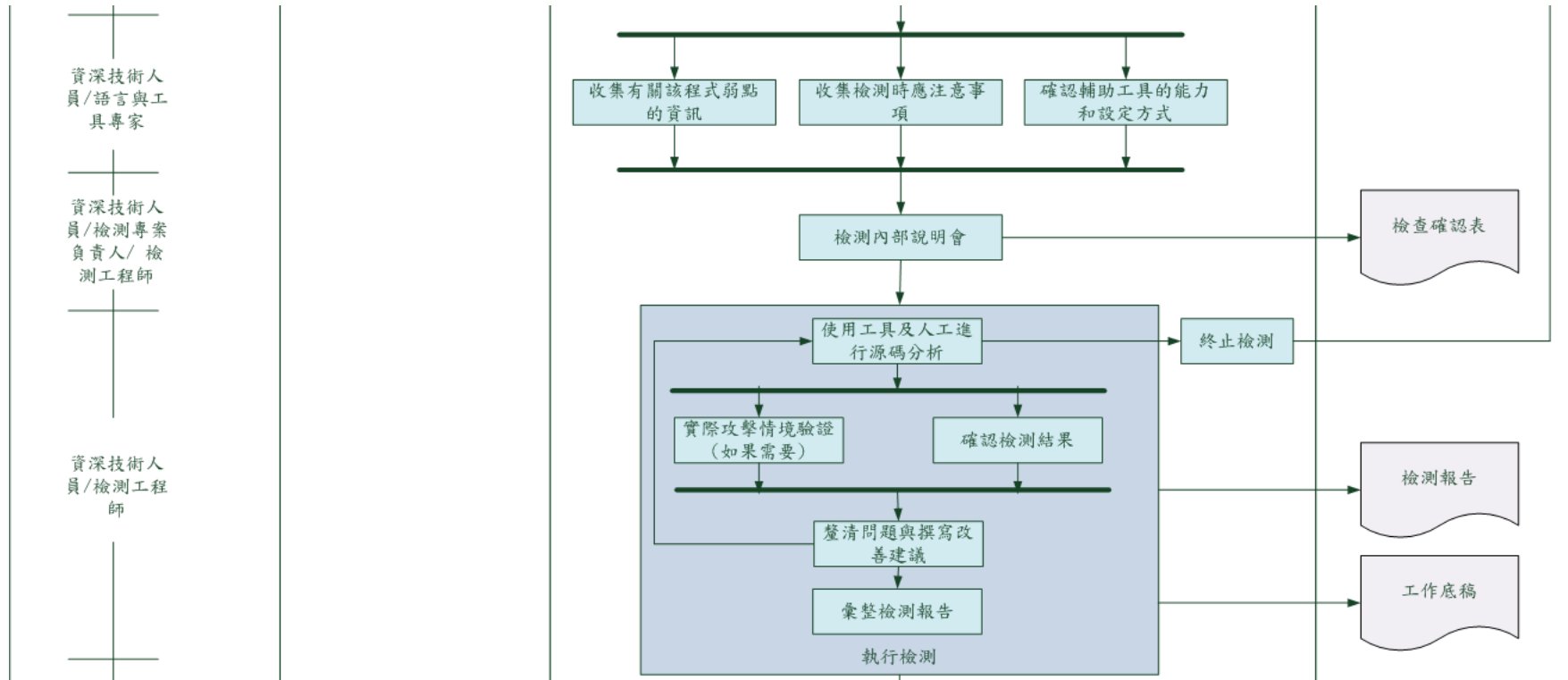
項目	指標	計算方式
能夠有效辨識軟體當中的弱點	M11: 誤報率在 _____ % 以下	每次進行專案後，在專案報告時，統計： 委託方所同意的風險/提出的風險數*100% 或是在一個期間後 (如一年)，進行統計
	M12: 漏報數在 _____ % 以下	每隔一段期間，統計： 委託方提出沒有找到的弱點數/該期間總提出的風險數*100%
能夠協助委託方避免程式安全弱點	M21: 委託方認知弱點的成因比率為 _____ % 以上	針對專案或是一時間區間，統計： 委託方能理解的弱點數/提出的風險數*100%
	M22: 委託方知道可以如何修補弱點的比率為 _____ % 以上	針對專案或是一時間區間，統計： 委託方知道如何修補的弱點數/提出的風險數*100%
能夠有效率的完成檢測工作	M31: 檢測工作能夠如期完成的比率在 _____ % 以上	針對一時間區間，統計： 如期完成的檢測計畫/ 總檢測計畫數*100%
避免重要機敏資料外洩	M41: 資訊外洩之意外事件在 _____ 件以下	針對一時間區間，統計意外事件所發生的件數
能夠提供使委託方滿意之服務	M51: 對檢測結果感到滿意的委託方在 _____ % 以上	針對一時間區間，對該期間內所執行完畢的檢測計畫之委託方進行調查，統計： 回答滿意的委託方/總委託方*100%



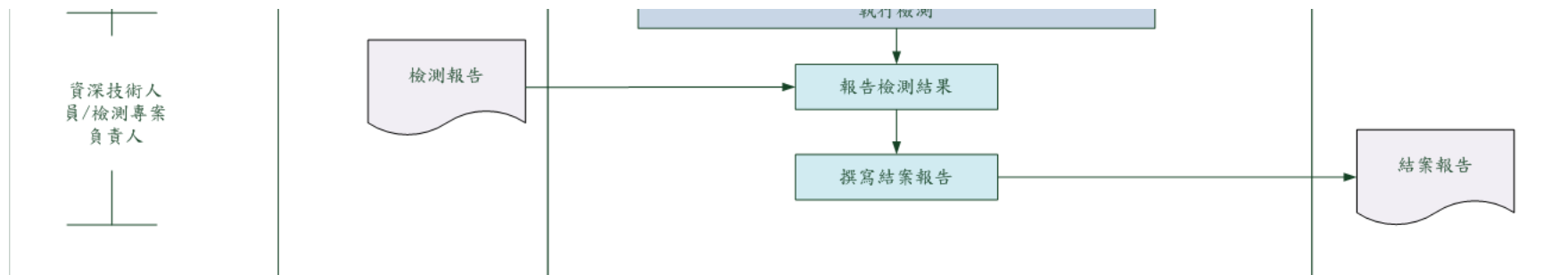
網頁應用程式檢測流程 (1/3)



網頁應用程式檢測流程 (2/3)

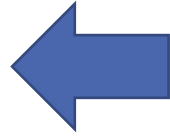


網頁應用程式檢測流程 (3/3)



效能評估

- 9.1監控、衡量、分析，與評估
- 9.2內部稽核
- 9.3管理審查



拆了章節，但內容沒太大差異



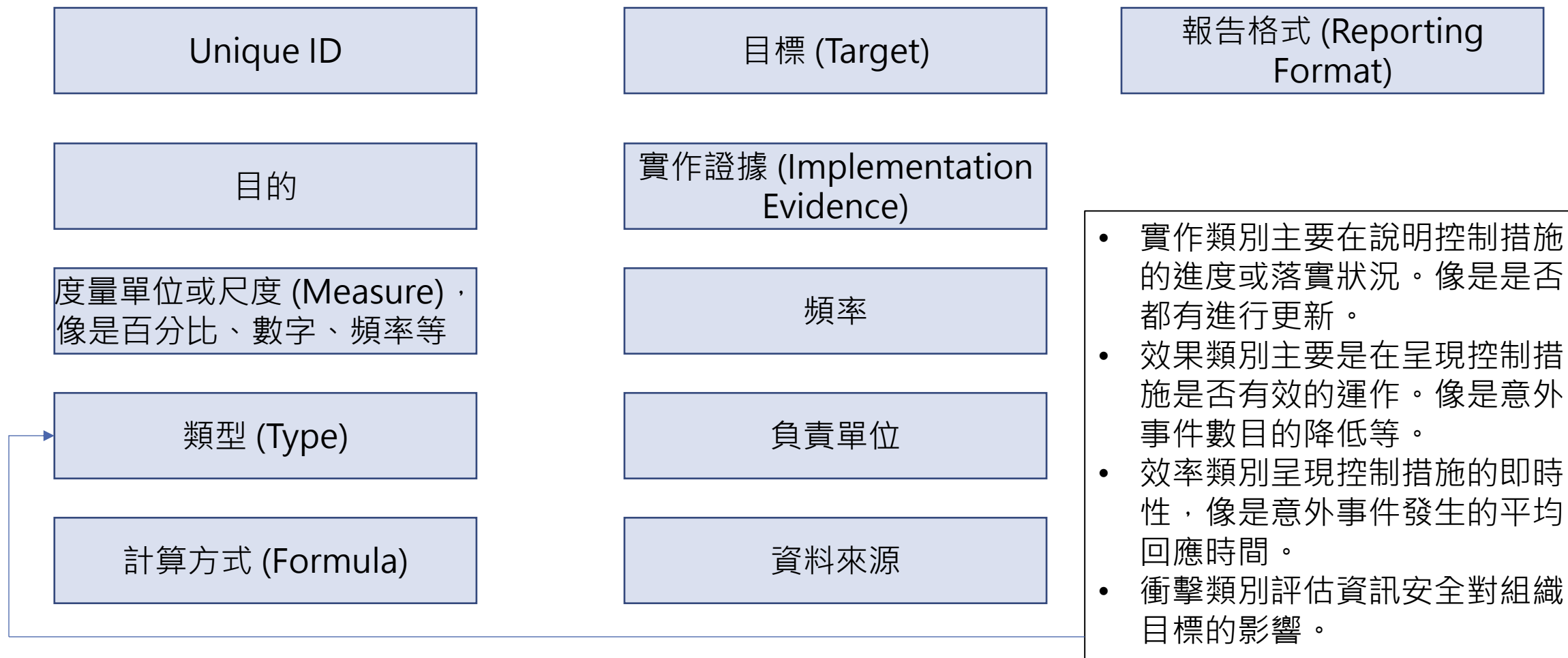
多了對於管理審查結果的要求

9. 績效評估

9.1 監督、量測、分析及評估

- 組織應決定下列事項：
 - (a) 需要監督及量測之事項， 包括資訊安全過程及控制措施。
 - (b) 監督、量測、分析及評估之適用方法， 以確保有效的結果。所選擇之方法宜產生適於比較及可重製視為有效的結果。
 - (c) 應執行監督及量測之時間。
 - (d) 應執行監督及量測之人員。
 - (e) 監督及量測結果應分析及評估之時間。
 - (f) 應執行分析及評估此等結果之人員。
- 應具備文件化資訊， 作為結果之證據。
- 組織應評估資訊安全績效及資訊安全管理系統之有效性。

對於指標定義應該要包括的資訊



定義、收集，與分析指標的程序



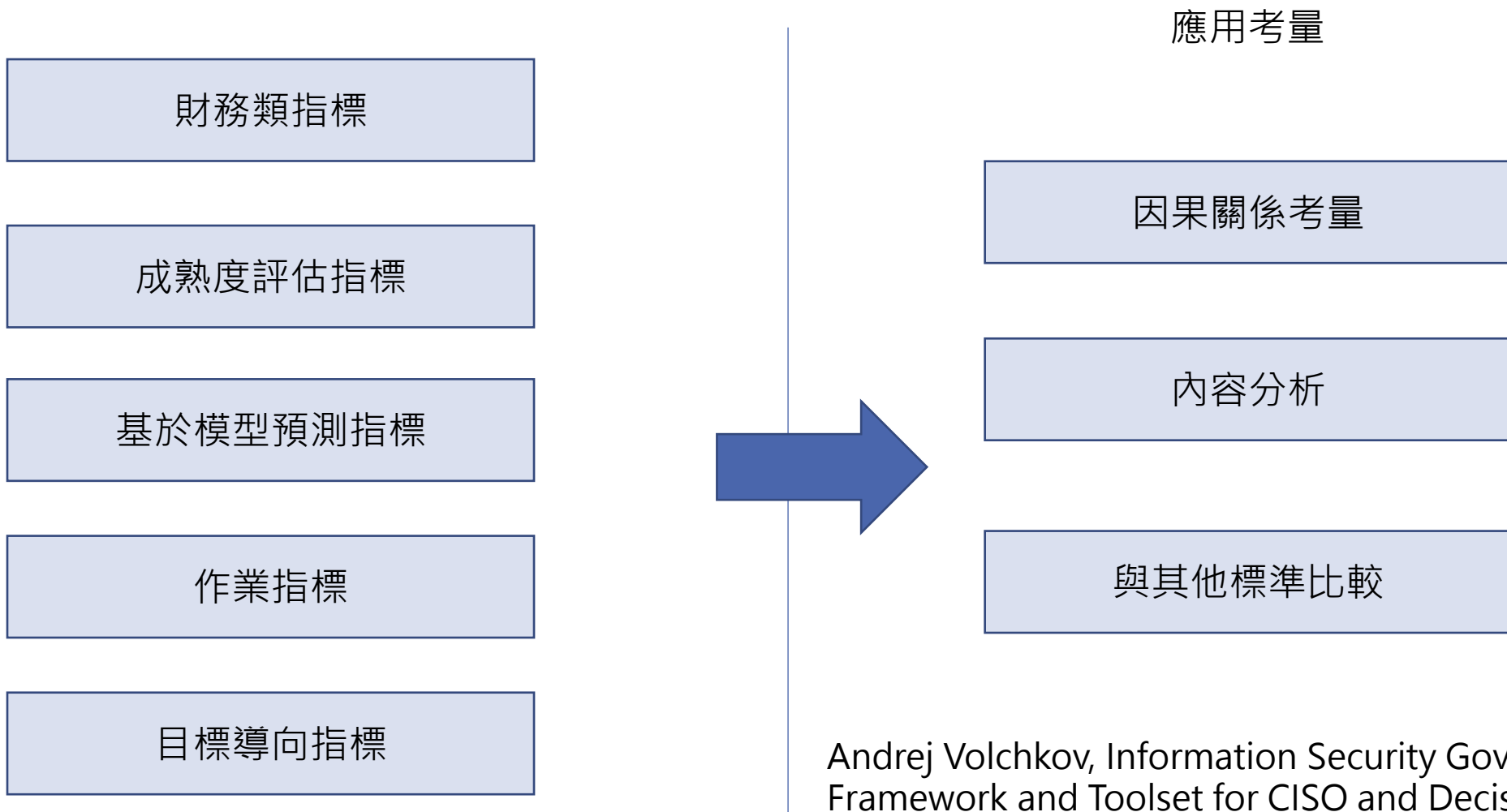
- 測量通常和資料的收集相關
- 評估通常是判斷價值、性能，和狀態

- 資料驗證 (Data Validation)
- 正規化 (Normalization)
- 轉換 (Transformation)
- 指派 (Imputation)

選擇上可以評估指標用途：

- 是否可以用來識別不滿意效能的原因
- 能夠指出可以改進的區域
- 可以更容易一致性的落實政策
- 能夠協助重新定義目標
- 能夠協助修改資安政策

類別

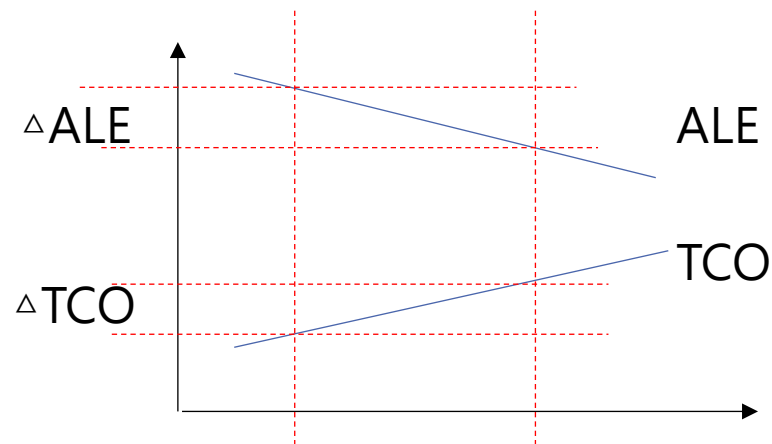


Andrej Volchkov, Information Security Governance:
Framework and Toolset for CISO and Decision Maker

財務指標

這最大的困難是計算期望損失

- 針對特定投資
 - 資安投資回報 (return on security investments, ROSI) :
 - Impact of the inherent risk = Cost of incident x P(inherent risk)
 - Impact of the residual risk = Cost of incident x P(residual risk)
 - Benefit (EVA) = Impact of inherent risk - Impact of residual risk
 - ROSI = Benefit - Cost of countermeasures
 - 保護能力指標
 - PCI (Protection Capacity Index) = $(IR - RR) / IR$ (越接近 1 表 RR 越低，表示保護效果越好)
- 整體投資指標
 - ALE：看期望損失
 - TCO：看整體資安成本
 - EVA (Economic value added) = $\Delta ALE / \Delta TCO$
 - 應該要小於 1



策略面評估方式

領域	問題
策略	• 是否有定義資安策略？ • 資安策略有連結到業務目標的比率？ • 管理層對安全問題的理解？ • 資安長是否有參與業務策略的制定？
政策	• 安全政策和指引的制定是否符合考慮業務單位的意見？ • 是否有手段監控資安政策與指引的有效性？ • 政策是否考量相關員工的責任？是否有定義違反的罰則？ • 是否建立了內部政策與程序的文件管理框架？ • 是否有建立政策和指引的變更管理程序？ • 安全政策如何驗證？
組織	• 是否有指派資安治理的責任？ • 資安主管及資安部門在組織中的位置是否容易考慮業務單位的需求？ • 是否有資安委員會，以便能對安全政策和程序的例外情況和變更作出裁決？ • 資安主管是否有與業務單位雙向溝通資安目標的管道？

戰術面評估方式

領域	問題
風險	- 資安風險管理是否與公司的作業風險管理整合？ - 業務單位的風險管理人員在分析資安風險時是否有參與？ - 風險清單是否與所有業務單位確認？ - 是否有衡量資安控制效能的度量和關鍵績效指標 (KPI)？ - 是否制定了資安風險處理計劃？
資訊安全計畫管理	- 董事會、高階管理層和業務單位領導是否有參與設定安全優先事項？ - 業務單位經理是否有參與在安全計劃之優先排序？ - 業務單位是否參與了資訊安全部門業務計劃的制定？ - 所有技術解決方案的支出是否經過風險和成本效益分析的合理性評估？ - 資訊安全計目標是否明確定義？ - 是否有關於作業控制的清單，其中包含責任、成熟度水準和驗證測試計劃？ - 是否建立了宣導計畫，以提升員工資產保護意識？
報告	- 是否有針對管理層、董事會和業務單位的資訊安全報告制度？ - 報告是否包含有關資訊安全狀態、高風險、合規性和成熟度的差距，以及所採取措施有效性與相關資料？

戰術面評估方式 (續)

領域	問題
資產管理	• 是否識別資料，並進行分類和分級？ • 是否識別資料的所有者？ • 資料所有者的隱私、可用性和完整性等要求是否被整合到安全計劃中？
符合性	• 是否已識別資安相關的法律和法規？ • 是否建立將法律和法規框架傳達給員工的管道？ • 是否建立了合規計劃？
指標	• 是否了解資訊安全的直接、間接成本與各類活動成本？ • 是否有衡量各種安全控制效能的指標？ • 是否有方法衡量員工在威脅和保護措施方面的訓練程度？ • 業務部門如何參與驗證資訊安全指標？

9.2 內部稽核

9.2.1 一般要求

- 組織應依規劃之期間施行內部稽核，以提供資訊安全管理系統的下列資訊：
- (a) 是否符合下列事項：
 - (1) 組織本身對其資訊安全管理系統之要求事項。
 - (2) 本標準之要求事項。
- (b) 是否有效實作及維持。

9.2.2 內部稽核計畫

- 組織應規劃、建立、實作及維持稽核計畫，包括頻率、方法、責任、規劃要求事項及報告。
- 於建立內部稽核計畫時，組織應考量所關切過程之重要性及先前稽核的結果。
- 組織應採取下列作為：
- (a) 定義各稽核之稽核準則及稽核範圍。
- (b) 選擇稽核員及施行稽核，以確保稽核過程之客觀性及公平性。
- (c) 確保稽核之結果對相關管理階層報告。
- 應具備文件化資訊，作為稽核計畫實作及稽核結果之證據。

9.3 管理審查

9.3.1 一般要求

- 最高管理階層應於規劃之期間， 審查組織之資訊安全管理系統， 以確保其持續的合宜性、適切性及有效性。

9.3.2 管理審查輸入

- 管理審查應包括對下列事項之考量：
- (a) 過往管理審查之決議的處理狀態。
- (b) 與資訊安全管理系統有關之外部及內部議題的變更。
- (c) 與資訊安全管理系統相關關注方之需要及期望的變更。
- (d) 資訊安全績效之回饋， 包括下列之趨勢：
 - (1) 不符合事項及矯正措施。
 - (2) 監督及量測結果。
 - (3) 稽核結果。
 - (4) 資訊安全目標之達成。
- (e) 關注方之回饋。
- (f) 風險評鑑結果及風險處理計畫之狀態。
- (g) 持續改善之機會。

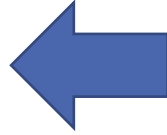
9.3.3 管理審查結果

- 管理審查之結果應包括與持續改善機會相關的決策，以及任何對資訊安全管理系統變更之需要。
- 應具備文件化資訊，以作為管理審查結果之證據。

改進

10.1持續改進

10.2對不符合事項的追蹤



章節的順序改了

10. 改進

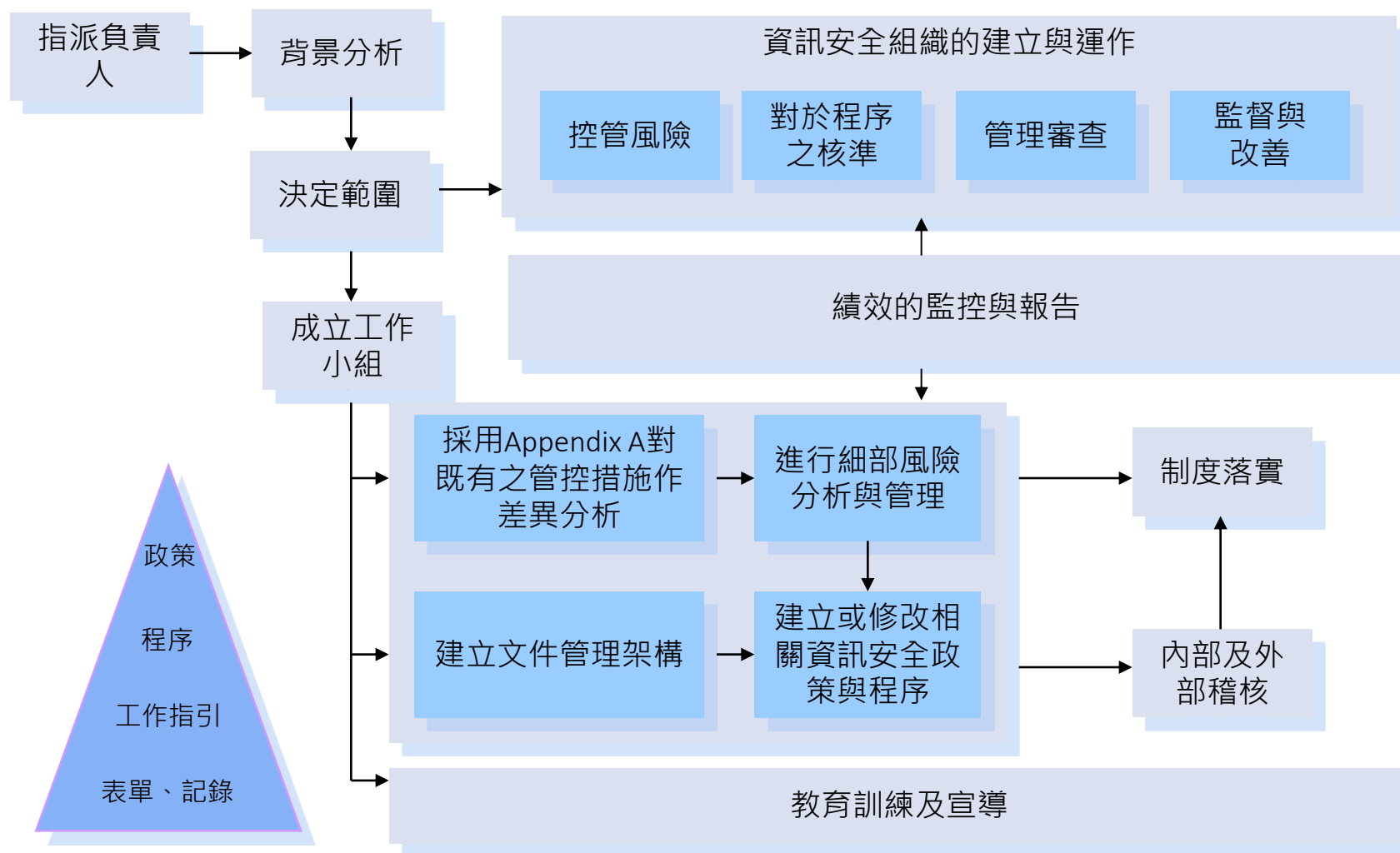
10.1 持續改善

- 組織應持續改善資訊安全管理系統之合宜性、適切性及有效性。

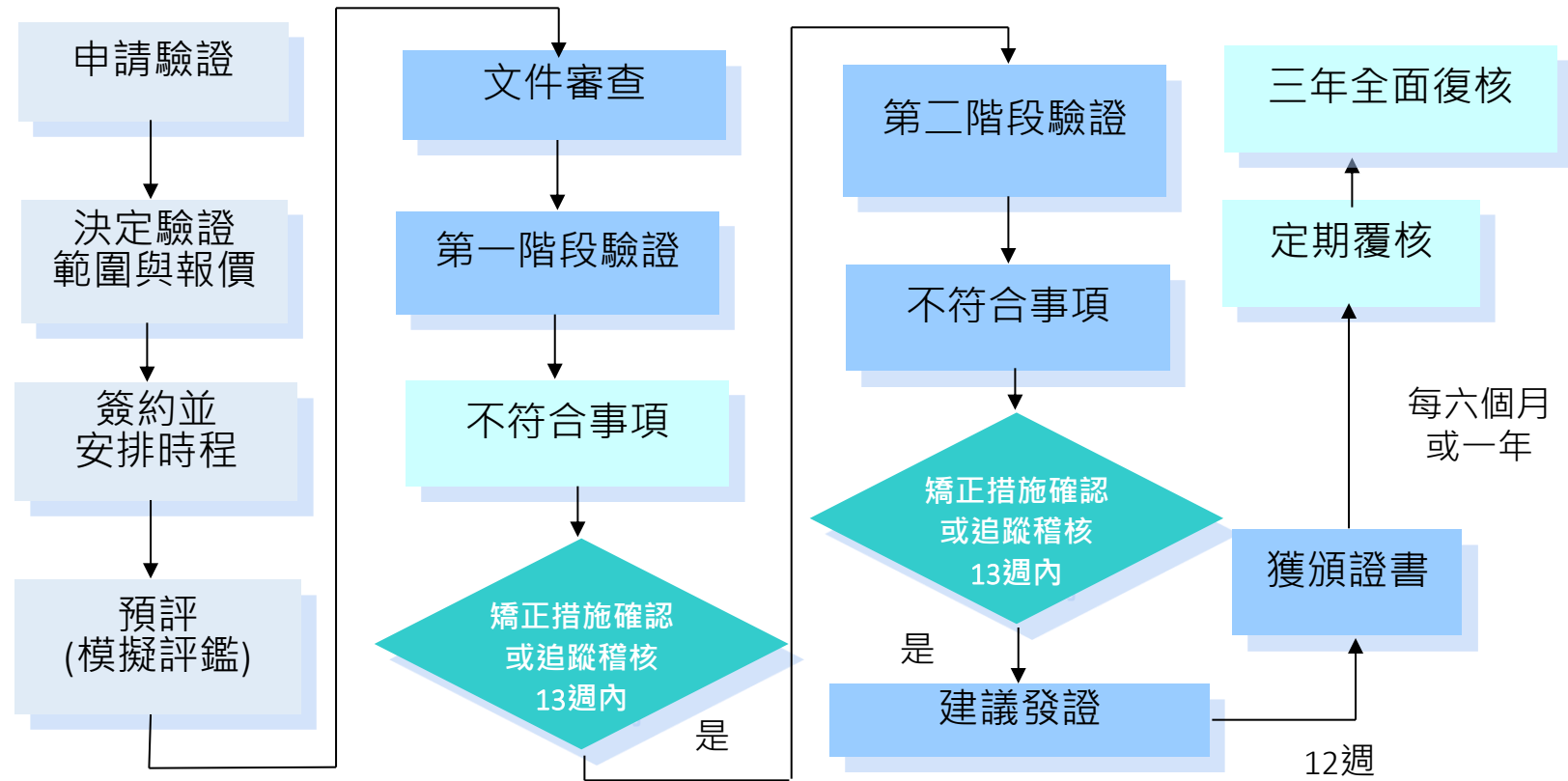
10.2 不符合事項及矯正措施

- 不符合事項發生時，組織應有下列作為：
- (a) 對不符合事項反應，並於適用時，採取下列作為：
 - (1) 採取行動，以控制並矯正之。
 - (2) 處理其後果。
- (b) 藉由下列作為，評估對消除不符合事項之原因的行動之需要，使其不再發生且不於他處發生：
 - (1) 審查不符合事項。
 - (2) 判定不符合事項之原因。及
 - (3) 判定是否有類似之不符合事項存在，或可能發生。
- (c) 實作所有所需行動。
- (d) 審查所有所採取矯正措施之有效性。
- (e) 必要時，對資訊安全管理系統進行變更。
- 矯正措施應切合所遇到不符合事項之影響。
- 應具備文件化資訊，以作為下列事項之證據：
- (f) 不符合事項之性質及後續採取的所有行動。
- (g) 所有矯正措施之結果。

導入重點



ISO27001驗證流程



各階段稽核目標

- 驗證第一階段

- 文件審查

- 標準要求之文件、程序書等是否齊備？

- 驗證第一階段

- 驗證範圍與適用性聲明是否適當？
 - 確認管理系統的運作型態和文件化程度？
 - 管理系統是否依風險評估結果所建立？
 - 審查及驗證是否可信賴？

- 驗證第二階段

- 文件化的管理系統是否符合相關標準？
 - 管理程序是否確實執行？
 - 管理系統方面是否能達到持續改善及法規遵循？



不符合事項定義 - 第一類 (Category 1)

- 系統某單元完全沒有執行，或同一單元有多個 Cat 2 NC 使得該單元無法有效執行
- 違反系統/程序要求事件，且會引起顯著資訊安全損失的風險
- 存在明顯立即資訊安全損失的風險
- 重大資訊安全風險並未被鑑別及檢討改善
- 不合法規 (資訊安全)
- 前一次Cat 2 NC未改善

不符合事項定義 - 第二類 (Category 2)

- 單獨違反系統/程序要求事件，且不會引起顯著資訊安全損失的風險。

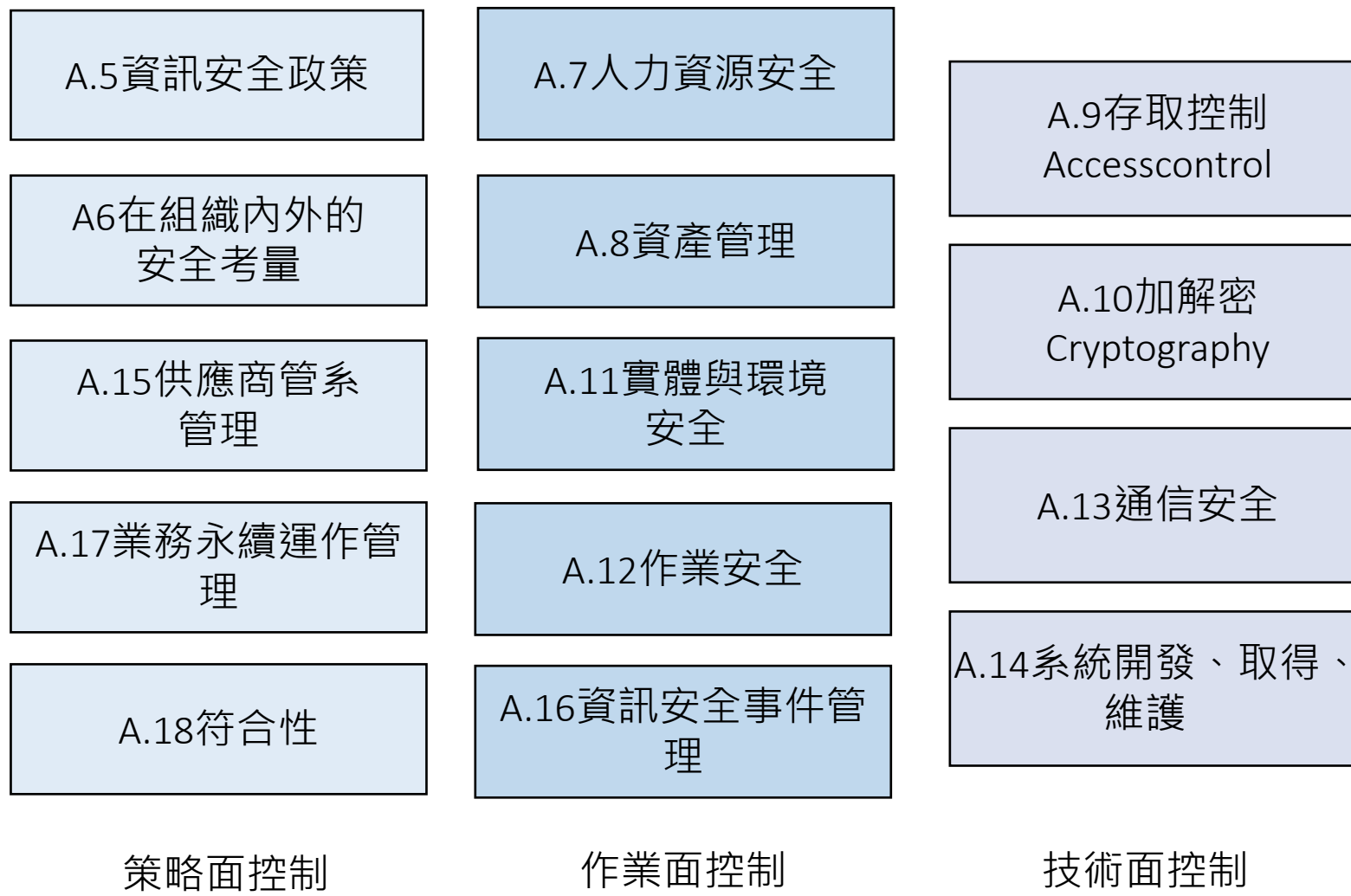
不符合事項定義：觀察事項 (Observation)

- 發現系統/程序有潛在不恰當的情形
- 或具有潛在資訊安全損失的風險
- 提供客戶及評審員在後續評審中的參考

矯正及預防措施

- 在期限內提出有效矯正措施並經稽核員核可
 - 首次驗證稽核
 - Cat. 1 及Cat. 2 NCs：13 週
 - 定期稽核與全面複核
 - Cat. 1 NCs：6 週
 - Cat. 2 NCs: 13 週
- 不符合事項核可之要求
 - Cat. 1 NCs
 - 需有改善完成之證據
 - Cat. 2 NCs
 - 若短期內未能完成改善，需提出完整改善計畫
 - Observations
 - 被稽核單位自行決定改善與否，下次稽核查核重點之一

ISO/IEC27001:2013的建議控制目標



其實還是可以用執行能力去做對應



ISO/IEC27001:2013策略面控制

A.5資訊安全政策(2)
A.5.1管理階層對於資訊安全的指引
A.5.1.1建立資訊安全政策
A.5.1.2對於相關政策的審查

A.6在組織內外的安全考量(7)
A.6.1組織內安全
A.6.1.1資訊安全角色與責任
A.6.1.2分工
A.6.1.3與主管單位的聯繫
A.6.1.4與特殊利害關係團體的聯繫
A.6.1.5專案管理中的資訊安全考量
A.6.2行動裝置與遠端工作安全
A.6.2.1行動裝置安全
A.6.2.2遠端工作

A.15供應商關係(5)
A.15.1往來供應商的資訊安全
A.15.1.1對供應商的資訊安全政策
A.15.1.2與供應商協定的安全要求
A.15.1.3供應鏈的資訊與溝通技術安全
A.15.2供應商服務提供管理
A.15.2.1對供應商服務的監控與審查
A.15.2.2對供應商服務的變更管理

A.17業務永續運作管理(4)
A.17.1資訊安全持續
A.17.1.1規劃資訊安全持續
A.17.1.2實作資訊安全持續
A.17.1.3查證、審查，並評估資訊安全持續
A.17.2多重備援
A.17.2.1資訊處理設施之可用性

A.18符合性(8)
A.18.1對於法律與契約要求事項之遵循
A.18.1.1識別適用之法規與契約要求事項
A.18.1.2智慧財產權
A.18.1.3紀錄之保護
A.18.1.4個人可識別資訊之隱私與保護
A.18.1.5符合使用加解密控制之規定
A.18.2資訊安全審查
A.18.2.1資訊安全的獨立性審查
A.18.2.2符合資訊安全政策與標準
A.18.2.3技術符合性審查

ISO/IEC27001:2013作業面控制

A.7人力資源安全(6)

A.7.1聘僱前

A.7.1.1背景篩選

A.7.1.2聘僱條款

A.7.2聘僱中

A.7.2.1管理階層責任

A.7.2.2資訊安全認知、教育、訓練

A.7.2.3懲處過程

A.7.3聘用之終止與變更

A.7.3.1聘用責任之終止與變更

A.8資產管理(10)

A.8.1資產責任

A.8.1.1資產清冊

A.8.1.2識別所有權

A.8.1.3資產之可被接受使用

A.8.1.4資產之歸還

A.8.2資訊分類

A.8.2.1資訊分類

A.8.2.2資訊標記

A.8.2.3資產之處置

A.8.3儲存媒體之處置

A.8.3.1可移動儲存媒體之管理

A.8.3.2儲存媒體之汰除

A.8.3.3實體媒體之傳送

A.11實體與環境安全(15)

A.11.1安全區域

A.11.1.1實體安全邊界

A.11.1.2實體進入控制

A.11.1.3辦公室、房間、設施之保全A.11.1.4

防範外部與環境威脅

A.11.1.5在安全區域內工作之規定

A.11.1.6交付與裝卸區

A.11.2設備

A.11.2.1設備安置與保護

A.11.2.2支援設施與資源

A.11.2.3纜線安全

A.11.2.4設備維護

A.11.2.5資產攜出

A.11.2.6場所外之設備與資產之安全A.11.2.7

設備報廢與重新使用之安全A.11.2.8無人看

管設備之保護

A.11.2.9桌面及螢幕淨空

A.16資訊安全事件管理(7)

A.16.1資訊安全意外事件的管理與改進

A.16.1.1責任與程序

A.16.1.2通報資訊安全事件

A.16.1.3通報資訊安全弱點

A.16.1.4對資訊安全事件之評估與決策

A.16.1.5對安全意外事件之回應

A.16.1.6從資訊安全意外事件中學習A.16.1.7

證據收集

A.12作業安全(14)

A.12.1作業安全之程序與責任

A.12.1.1文件化的作業程序

A.12.1.2變更管理

A.12.1.3容量管理

A.12.1.4分隔開發、測試、與線上環境

A.12.2惡意軟體防禦

A.12.2.1限制惡意軟體

A.12.3備份

A.12.3.1資訊備份

A.12.4紀錄與監控

A.12.4.1事件紀錄

A.12.4.2保護紀錄資訊

A.12.4.3管理者與操作者日誌

A.12.4.4時鐘同步

A.12.5對運作中軟體安裝之管理

A.12.5.1於系統中安裝軟體之限制

A.12.6技術弱點管理

A.12.6.1管理技術弱點

A.12.6.2限制軟體安裝

A.12.7資訊系統稽核的考量

A.12.7.1資訊系統稽核控制措施

ISO/IEC27001:2013技術面控制

A.9存取控制(14)

A.9.1存取控制之業務面需求

A.9.1.1存取控制政策

A.9.1.2對網路與網路服務之存取

A.9.2使用者存取管理

A.9.2.1使用者註冊與註銷

A.9.2.2使用者存取權限配置

A.9.2.3特權管理

A.9.2.4使用者秘密鑑別資訊的管理

A.9.2.5使用者存取審查

A.9.2.6存取權限之移除或調整

A.9.3使用者責任

A.9.3.1秘密鑑別資訊之使用

A.9.4系統與應用程式存取控制

A.9.4.1資訊存取限制

A.9.4.2安全登入程序

A.9.4.3密碼管理系統

A.9.4.4限制特權工具程式的使用

A.9.4.5對於程式原始碼的存取限制

A.10加解密(2)

A.10.1加解密機制控制

A.10.1.1加解密機制使用政策

A.10.1.2金鑰管理

A.13通信安全(7)

A.13.1網路安全管理

A.13.1.1網路控制

A.13.1.2安全的網路服務

A.13.1.3網路分割

A.13.2資訊傳輸

A.13.2.1資訊傳輸政策與程序

A.13.2.2資訊傳輸協議

A.13.2.3電子訊息

A.13.2.4保密或資訊不可揭露協議

A.14系統開發、取得、維護(13)

A.14.1資訊系統的安全需求

A.14.1.1資訊安全需求分析與規格定義

A.14.1.2公共網路上提供應用服務之安全

A.14.1.3應用服務交易保護

A.14.2開發與支援程序之安全

A.14.2.1安全開發政策

A.14.2.2系統變更控制程序

A.14.2.3作業平台變更後的應用程式技術審查

A.14.2.4限制對於套裝軟體的變更

A.14.2.5遵守系統工程安全原則

A.14.2.6保護開發環境安全

A.14.2.7委外開發管理

A.14.2.8系統安全測試

A.14.2.9系統驗收測試

A.14.3測試資料

A.14.3.1保護測試資料

組織的控制 (1/7)

2022	2013	控制類型	安全概念	作業能力	安全領域
5.1資訊安全政策	A.5.1.1建立資訊安全政策 A.5.1.2對於相關政策的審查	#Preventive	#Identify	#Governance	#Governance_ and_Ecosystem #Resilience
5.2資訊安全角色與責任	A.6.1.1 資訊安全角色與責任	#Preventive	#Identify	#Governance	#Governance_ and_Ecosystem #Protection #Resilience
5.3分工	A.6.1.2 分工	#Preventive	#Protect	#Governance #Identity_and_ access_man- agement	#Governance_ and_Ecosystem
5.4管理者責任	A.7.2.1管理階層責任	#Preventive	#Identify	#Governance	#Governance_ and_Ecosystem
5.5與權責單位聯繫	A.6.1.3與權責單位的聯繫	#Preventive #Corrective	#Identify #Protect #Respond #Recover	#Governance	#Defense #Resilience

組織的控制 (2/7)

2022	2013	控制類型	安全概念	作業能力	安全領域
5.6與特殊利害關係團體聯繫	A.6.1.4與特殊利害關係團體的聯繫	#Preventive #Corrective	#Protect #Respond #Recover	#Governance	#Defense
5.7威脅情資	新增	#Preventive #Detective #Corrective	#Identify #Detect #Respond	#Threat_and_vulnerability_management	#Defense #Resilience
5.8在專案管理中內入資訊安全	A.6.1.5 專案管理中的資訊安全考量 A.14.1.1資訊安全需求分析與規格定義	#Preventive	#Identify #Protect	#Governance	#Governance_and_Ecosystem #Protection
5.9資訊與其他資產的盤點	A.8.1.1資產清冊 A.8.1.2 識別所有權	#Preventive	#Identify	#Asset_management	#Governance_and_Ecosystem #Protection
5.10資訊與其他資產可接受的使用方式	A.8.1.3資產之可被接受使用 A.8.2.3資產之處置	#Preventive	#Protect	#Asset_management #Information_protection	#Governance_and_Ecosystem #Protection

組織的控制 (3/7)

2022	2013	控制類型	安全概念	作業能力	安全領域
5.11資產歸還	A.8.1.4 資產之歸還	#Preventive	#Protect	#Asset_management	#Protection
5.12資訊分類	A.8.2.1 資訊分類	#Preventive	#Identify	#Information_protection	#Protection #Defense
5.13資訊標記	A.8.2.2 資訊標記	#Preventive	#Protect	#Information_protection	#Protection #Defense
5.14資訊傳遞	A.13.2.1 資訊傳輸政策與程序 A.13.2.2 資訊傳輸協議 A.13.2.3 電子訊息	#Preventive	#Protect	#Asset_management #Information_protection	#Protection
5.15存取控制	A.9.1.1 存取控制政策 A.9.1.2 對網路與網路服務之存取	#Preventive	#Protect	#Identity_and_access_management	#Protection
5.16身分管理	A.9.2.1使用者註冊與註銷	#Preventive	#Protect	#Identity_and_access_management	#Protection

組織的控制 (4/7)

2022	2013	控制類型	安全概念	作業能力	安全領域
5.17鑑別資訊	A.9.2.4使用者秘密鑑別資訊的管理 A.9.3.1秘密鑑別資訊之使用 A.9.4.3密碼管理系統	#Preventive	#Protect	#Identity_and_access_management	#Protection
5.18存取權限	A.9.2.2使用者存取權限配置 A.9.2.5使用者存取審查 A.9.2.6存取權限之移除或調整	#Preventive	#Protect	#Identity_and_access_management	#Protection
5.19供應關係中的資訊安全	A.15.1.1對供應商的資訊安全政策	#Preventive	#Identify	#Supplier_relationships_security	#Governance_and_Ecosystem #Protection
5.20在供應協定中考量資訊安全	A.15.1.2與供應商協定的安全要求	#Preventive	#Identify	#Supplier_relationships_security	#Governance_and_Ecosystem #Protection
5.21在ICT的供應中管理資訊安全	A.15.1.3供應鏈的資訊與溝通技術安全	#Preventive	#Identify	#Supplier_relationships_security	#Governance_and_Ecosystem #Protection

組織的控制 (5/7)

2022	2013	控制類型	安全概念	作業能力	安全領域
5.22供應商服務的監控、審查，與變更管理	A.15.2.1對供應商服務的監控與審查 A.15.2.2對供應商服務的變更管理	#Preventive	#Identify	#Supplier_relationships_security	#Governance_and_Ecosystem #Protection #Defense
5.23使用雲端服務的資訊安全	新增	#Preventive	#Protect	#Supplier_relationships_security	#Governance_and_Ecosystem #Protection
5.24規劃與準備意外事件管理	A.16.1.1責任與程序	#Corrective	#Respond #Recover	#Governance #Information_security_event_management	#Defence
5.25資訊安全事件的評估與決定	A.16.1.4對資訊安全事件之評估與決策	#Detective	#Respond #Detect	#Information_security_event_management	#Defence
5.26資訊安全意外事件的回應	A.16.1.5安全意外事件之回應	#Corrective	#Respond #Recover	#Information_security_event_management	#Defence
5.27從資訊安全意外事件中學習	A.16.1.6從資訊安全意外事件中學習	#Preventive	#Identify #Protect	#Information_security_event_management	#Defence

組織的控制 (6/7)

2022	2013	控制類型	安全概念	作業能力	安全領域
5.28證據收集	A.16.1.7證據收集	#Corrective	#Detect #Respond	#Information_security_event_management	#Defense
5.29在中斷時的資訊安全	A.17.1.1規劃資訊安全持續 A.17.1.2實作資訊安全持續 A.17.1.3查證、審查，並評估資訊安全持續	#Preventive #Corrective	#Protect #Respond	#Continuity	#Protection #Resilience
5.30ICT在業務永續中準備就緒	新增	#Corrective	#Respond	#Continuity	#Resilience
5.31法律、命令、規則，與合約要求	A.18.1.1 識別適用之法規與契約要求事項 A.18.1.5符合使用加解密控制之規定	#Preventive	#Identify	#Legal_and_compliance	#Governance_and_Ecosystem #Protection
5.32智慧財產權	A.18.1.2智慧財產權	#Preventive	#Identify	#Legal_and_compliance	#Governance_and_Ecosystem

組織的控制 (7/7)

#Asset_management #Physical_security #System_and_network_security
 #Application_security #Secure_configuration #Identity_and_access_management
 #Threat_and_vulnerability_management #Continuity
 #Information_security_event_management

2022	2013	控制類型	安全概念	作業能力	安全領域
5.33保護紀錄	A.18.1.3紀錄之保護	#Preventive	#Identify #Protect	#Legal_and_compliance #Asset_management #Information_protection	#Defense
5.34個人可識別資訊的隱私與保護	A.18.1.4個人可識別資訊之隱私與保護	#Preventive	#Identify #Protect	#Information_protection #Legal_and_compliance	#Protection
5.35資訊安全的獨立審查	A.18.2.1資訊安全的獨立性審查	#Preventive #Corrective	#Identify #Protect	#Information_security_assurance	#Governance_and_Ecosystem
5.36資訊安全政策、規則、標準的符合	A.18.2.2符合資訊安全政策與標準 A.18.2.3技術符合性審查	#Preventive	#Identify #Protect	#Legal_and_compliance #Information_security_assurance	#Governance_and_Ecosystem
5.37作業程序的文件化	A.12.1.1文件化的作業程序	#Preventive #Corrective	#Protect #Recover		#Governance_and_Ecosystem #Protection #Defence

人員的控制 (1/2)

2022	2013	控制類型	安全概念	作業能力	安全領域
6.1背景過濾	A.7.1.1背景篩選	#Preventive	#Protect	#Human_resource_security	#Governance_and_Ecosystem
6.2聘僱條款	A.7.1.2聘僱條款	#Preventive	#Protect	#Human_resource_security	#Governance_and_Ecosystem
6.3資訊安全教育訓練與宣導	A.7.2.2資訊安全認知、教育、訓練	#Preventive	#Protect	#Human_resource_security	#Governance_and_Ecosystem
6.4處分程序	A.7.2.3懲處過程	#Preventive #Corrective	#Protect #Respond	#Human_resource_security	#Governance_and_Ecosystem
6.5聘僱終止與變更後的責任	A.7.3.1聘用責任之終止與變更	#Preventive	#Protect	#Human_resource_security #Asset_management	#Governance_and_Ecosystem
6.6保密合約	A.13.2.4 保密或資訊不可揭露協議	#Preventive	#Protect	#Human_resource_security #Information_protection #Supplier_relationships	#Governance_and_Ecosystem

人員的控制 (2/2)

2022	2013	控制類型	安全概念	作業能力	安全領域
6.7遠端工作	A.6.2.2遠端工作	#Preventive	#Protect	#Asset_management #Information_protection #Physical_security #System_and_network_Security	#Protection
6.8資訊安全事件報告	A.16.1.2通報資訊安全事件	#Detective	#Detect	#Information_security_event_management	#Defence

實體控制 (1/2)

2022	2013	控制類型	安全概念	作業能力	安全領域
7.1實體安全邊界	A.11.1.1實體安全邊界	#Preventive	#Protect	#Physical_security	#Protection
7.2實體門禁	A.11.1.2實體進入控制 A.11.1.6交付與裝卸區	#Preventive	#Protect	#Physical_security #Identity_and_ Access_Management	#Protection
7.3保護辦公室與設施	A.11.1.3 辦公室、房間、設施之保全	#Preventive	#Protect	#Physical_security #Asset Management	#Protection
7.4實體安全監控	新增	#Preventive	#Protect	#Physical_security	#Protection
7.5避免實體與環境安全威脅	A.11.1.4防範外部與環境威脅	#Preventive	#Protect	#Physical_security	#Protection
7.6在安全區域中的工作	A.11.1.5在安全區域內工作之規定	#Preventive	#Protect	#Physical_security	#Protection
7.7桌面與螢幕淨空	A.11.2.9桌面及螢幕淨空	#Preventive	#Protect	#Physical_security	#Protection
7.8設備選地與保護	A.11.2.1設備安置與保護	#Preventive	#Protect	#Physical_security #Asset Management	#Protection
7.9資產在邊界外的安全	A.11.2.6場所外之設備與資產之安全	#Preventive	#Protect	#Physical_security #Asset Management	#Protection

實體控制 (2/2)

2022	2013	控制類型	安全概念	作業能力	安全領域
7.10儲存媒介	A.8.3.1可移動儲存媒體之管理 A.8.3.2儲存媒體之汰除 A.8.3.3實體媒體之傳送 A.11.2.5資產攜出	#Preventive	#Protect	#Physical_security #Asset Management	#Protection
7.11支援設施	A.11.2.2支援設施與資源	#Preventive #Detective	#Protect #Detect	#Physical_security	#Protection
7.12纜線安全	A.11.2.3纜線安全	#Preventive	#Protect	#Physical_security	#Protection
7.13設備維護	A.11.2.4設備維護	#Preventive	#Protect	#Physical_security #Asset Management	#Protection
7.14設備報廢與重用的安全	A.11.2.7設備報廢與重新使用之安全	#Preventive	#Protect	#Physical_security #Asset Management	#Protection

技術控制 (1/6)

2022	2013	控制類型	安全概念	作業能力	安全領域
8.1使用者終端裝置	A6.2.1行動裝置安全 A11.2.8無人看管設備之保護	#Preventive	#Protect	#Asset Management #Information_protection	#Protection
8.2特權存取權限	A.9.2.3特權管理	#Preventive	#Protect	#Identity_and_Access_Management	#Protection
8.3資訊存取限制	A.9.4.1資訊存取限制	#Preventive	#Protect	#Identity_and_Access_Management	#Protection
8.4對於原始碼的存取	A.9.4.5對於程式原始碼的存取限制	#Preventive	#Protect	#Identity_and_Access_Management #Application_security #Secure_configuration	#Protection
8.5安全鑑別	A.9.4.2 安全登入程序	#Preventive	#Protect	#Identity_and_Access_Management	#Protection
8.6容量管理	A.12.1.3容量管理	#Preventive #Detective	#Identify #Protect #Detect	#Continuity	#Governance_and_Ecosystem #Protection
8.7惡意程式防護	A.12.2.1限制惡意軟體	#Preventive #Detective #Corrective	#Protect #Detect	#System_and_network_security #Information_protection	#Protection #Defense

技術控制(2/6)

2022	2013	控制類型	安全概念	作業能力	安全領域
8.8技術弱點管理	A.12.6.1管理技術弱點 A.18.2.3技術符合性審查	#Preventive	#Identify #Detect	#Threat_and_vulnerability_management	#Governance_and_Ecosystem #Protection #Defense
8.9設定管理	新增	#Preventive	#Protect	#Secure_configuration	#Protection
8.10資訊刪除	新增	#Preventive	#Protect	#Information_protection #Legal_and_compliance	#Protection
8.11資料遮罩	新增	#Preventive	#Protect	#Information_protection	#Protection
8.12資料外洩防護	新增	#Preventive #Detective	#Protect #Detect	#Information_protection	#Protection #Defense
8.13資訊備份	A.12.3.1資訊備份	#Corrective	#Recover	#Continuity	#Protection
8.14資訊處理設施的備援	A.17.2.1資訊處理設施之可用性	#Preventive	#Protect	#Continuity #Asset Management	#Protection #Resilience
8.15紀錄	A.12.4.1事件紀錄 A.12.4.2保護紀錄資訊 A.12.4.3管理者與操作者日誌	#Detective	#Detect	#Information_security_event_management	#Protection #Defense

技術控制(3/6)

2022	2013	控制類型	安全概念	作業能力	安全領域
8.16監控活動	新增	#Detective #Corrective	#Detect #Respond	#Information_ security_ event_management	#Defense
8.17時鐘同步	A.12.4.4時鐘同步	#Detective	#Protect #Detect	#Information_ security_ event_management	#Protection #Defense
8.18特權工具程式的使用	A.9.4.4限制特權工具程式的使用	#Preventive	#Protect	#System_and_ network_security #Secure_configuration #Application_Security	#Protection
8.19在作業系統安裝軟體	A.12.5.1安裝軟體之限制 A.12.6.2限制軟體安裝	#Preventive	#Protect	#Secure_configuration #Application_security	#Protection
8.20網路安全	A.13.1.1網路控制	#Preventive #Detective	#Protect #Detect	#System_and_ network_security	#Protection
8.21網路服務安全	A.13.1.2安全的網路服務	#Preventive	#Protect	#System_and_ network_security	#Protection
8.22網路分隔	A.13.1.3網路分割	#Preventive	#Protect	#System_and_ network_security	#Protection

技術控制(4/6)

2022	2013	控制類型	安全概念	作業能力	安全領域
8.23網頁過濾	新增	#Preventive	#Protect	#System_and_network_security	#Protection
8.24加解密機制的使用	A.10.1.1加解密機制使用政策 A.10.1.2金鑰管理	#Preventive	#Protect	#Secure_configuration	#Protection
8.25安全的開發生命週期	A.14.2.1安全開發政策	#Preventive	#Protect	#Application_Security #System_and_network_security	#Protection
8.26應用程式安全需求	A.14.1.2公共網路上提供應用服務之安全 A.14.1.3作業平台變更後的應用程式技術審查	#Preventive	#Protect	#Application_Security #System_and_network_security	#Protection #Defense
8.27安全系統架構與工程原則	A.14.2.5遵守系統工程安全原則	#Preventive	#Protect	#Application_Security #System_and_network_security	#Protection
8.28程式開發時考量安全	新增	#Preventive	#Protect	#Application_Security #System_and_network_security	#Protection

技術控制(5/6)

2022	2013	控制類型	安全概念	作業能力	安全領域
8.29開發時的安全測試與驗收	A.14.2.8系統安全測試 A.14.2.9系統驗收測試	#Preventive	#Identify	#Application_security #Information_security_assurance #System_and_network_security	#Protection
8.30委外開發	A.14.2.7委外開發管理	#Preventive #Detective	#Identify #Protect #Detect	#System_and_network_security #Application_security #Supplier_relationships_Security	#Governance_and_Ecosystem #Protection
8.31區分開發、測試，與線上環境	A.12.1.4分隔開發、測試，與線上環境 A.14.2.6保護開發環境安全	#Preventive	#Protect	#Application_Security #System_and_network_security	#Protection
8.32變更管理	A.12.1.2變更管理 A.14.2.2系統變更控制程序 A.14.2.3作業平台變更後的應用程式技術審查 A.14.2.4限制對於套裝軟體的變更	#Preventive	#Protect	#Application_Security #System_and_network_security	#Protection

技術控制(6/6)

2022	2013	控制類型	安全概念	作業能力	安全領域
8.33測試資訊	A.14.3.1保護測試資料	#Preventive	#Protect	#Information_ Protection	#Protection
8.34在稽核測試的稽核測試	A.12.7.1資訊系統稽核控制措施	#Preventive	#Protect	#System_and_ network_security #Information_protection	#Governance_ and_Ecosystem #Protection

謝謝各位的聆聽

